

政風人員 資訊使用管理稽核

作業指引



臺北市府政風處

資訊安全防護基準檢核表（政風檢視部分）

資通安全責任等級

級之公務機關應辦事項

面項	檢測項目		檢測項目說明	資通安全責任等級	執行頻率	資通安全責任等級分級辦法（附表一至八）
管理面	資通系統分級及防護基準 (1. 系統分級請依據資通安全責任等級分級辦法附表九辦理，產出文件請參考資訊系統安全等級評估表。 2. 各系統控制措施請依據資通安全責任等級分級辦法附表十，產出文件請參考本檢核表【資通系統防護基準檢核表】與【伺服器安全基準檢核表】。)			A-B	一年內完成資通系統分級及控制措施；應每年至少檢視一次系統分級妥適性。	初次受核定或等級變更後之一年內，針對自行或委外開發之資通系統，依附表九完成資通系統分級，並完成附表十之控制措施；其後應每年至少檢視一次資通系統分級妥適性。
				C	一年內完成資通系統分級；應每年至少檢視一次系統分級妥適性；並應於二年內完成控制措施。	初次受核定或等級變更後之一年內，針對自行或委外開發之資通系統，依附表九完成資通系統分級；其後應每年至少檢視一次資通系統分級妥適性；並應於初次受核定或等級變更後之二年內，完成附表十之控制措施。
	資訊安全管理系統之導入及通過公正第三方之驗證 (1. 導入：可參考 CNS27001 或 ISO27001 相關制度與控制措施要求自行或委外導入，委外 RFP 文件可參考技服中心政府機關資訊安全管理系統 (ISMS) RFP。 2. 驗證：委外由第三方驗證公司辦理，RFP 文件可參考技服中心政府機關資訊安全管理系統 (ISMS) 第三方驗證 RFP。)			A-B	二年內全部核心資通系統導入 CNS 27001 或 ISO27001 等資訊安全管理系統標準，三年內完成公正第三方驗證，並持續維持其驗證有效性。	初次受核定或等級變更後之二年內，全部核心資通系統導入 CNS 27001 或 ISO27001 等資訊安全管理系統標準、其他具有同等或以上效果之系統或標準，或其他公務機關自行發展並經主管機關認可之標準，於三年內完成公正第三方驗證，並持續維持其驗證有效性。
				C	二年內全部核心資通系統導入 CNS 27001 或 ISO27001 等資訊安全管理系統標準，並持續維持導入。	初次受核定或等級變更後之二年內，全部核心資通系統導入 CNS 27001 或 ISO27001 等資訊安全管理系統標準、其他具有同等或以上效果之系統或標準，或其他公務機關自行發展並經主管機關認可之標準，並持續維持導入。
	資通安全專責人員 (針對專責人力之定義與業務範圍請見資通安全管理法常見問題)			A	一年內，配置四人（專職人員）。	初次受核定或等級變更後之一年內，配置四人；須以專職人員配置之。
				B	一年內，配置二人（專職人員）。	初次受核定或等級變更後之一年內，配置二人；須以專職人員配置之。
				C	一年內，配置一人（專職人員）。	初次受核定或等級變更後之一年內，配置一人；須以專職人員配置之。
	內部資通安全稽核 (臺北市政府及所屬各機關辦理資訊使用管理稽核作業規定)			A	每年辦理二次。	每年辦理二次。
				B	每年辦理一次。	每年辦理一次。
				C	每二年辦理一次。	每二年辦理一次。
	業務持續運作演練 (針對核心資通系統可參考 CNS27001 或 ISO27001 相關業務持續運作之程序書辦理，亦可參考技服中心 100 年度營運持續管理參考指引。)			A	每年辦理一次。	全部核心資通系統每年辦理一次。
				B-C	每二年辦理一次。	全部核心資通系統每二年辦理一次。
	資安治理成熟度評估 (A、B 級機關請依行政院通知期程每年至資安治理成熟度評審系統填報。)			A-B	每年辦理一次。	每年辦理一次。
	限制使用危害國家資通安全產品 (各機關對危害國家資通安全產品限制使用原則)			A-E	一、除因業務需求且無其他替代方案外，不得採購及使用危害國家資通安全產品。 二、應具體敘明理由，經主管機關核可後，以專案方式購置。 三、應列冊管理，且不得與公務網路環境介接。	一、除因業務需求且無其他替代方案外，不得採購及使用主管機關核定之廠商生產、研發、製造或提供之危害國家資通安全產品。 二、必須採購或使用危害國家資通安全產品時，應具體敘明理由，經主管機關核可後，以專案方式購置。 三、對本辦法修正施行前已使用或因業務需求且無其他替代方案經主管機關核可採購之危害國家資通安全產品，應列冊管理，且不得與公務網路環境介接。
認知與訓練	資通安全教育訓練 (本項由本府資訊局統籌辦理，亦可至台北 E 大取得相關學習時數。)	資通安全專職人員		A-C	每年十二小時以上（專業）。	每人每年至少接受十二小時以上之資通安全專業課程訓練或資通安全職能訓練。
		資通安全專職人員以外之資訊人員		A-C	每二年，三小時以上（專業）；每年三小時以上（通識）。	每人每二年至少接受三小時以上之資通安全專業課程訓練或資通安全職能訓練，且每年接受三小時以上之資通安全通識教育訓練。
		一般使用者及主管		A-E	每年三小時以上（通識）。	每人每年接受三小時以上之資通安全通識教育訓練。
	資通安全專業證照及職能訓練證書	資通安全專業證照 (本項由本府資訊局統籌辦理，有關係行政院認可之證照清單請見資通安全會報公告之資通安全專業證照清單。)		A/B/C	一年內專職人員應持有四 / 二 / 一張以上並持續維持證照之有效性。	初次受核定或等級變更後之一年內，資通安全專職人員總計應持有四 / 二 / 一張以上，並持續維持證照之有效性。
		資通安全職能評量證書 (參資安人才培訓服務網、資通安全管理法常見問題)		A/B/C	一年內專職人員應持有四 / 二 / 一張以上並持續維持證書之有效性。	初次受核定或等級變更後之一年內，資通安全專職人員總計應持有四 / 二 / 一張以上，並持續維持證書之有效性。

臺北市政府 109 年資訊使用管理稽核項目表

項次	項目名稱	查核紀錄文件	手冊頁碼
1. 系統查詢軌跡紀錄檔 (Log)：			
1-1	資訊單位是否有建立及啟動系統查詢軌跡紀錄檔 (Log)，並保存一段時間 (保存 _____)，以作為日後調查及監督之用。	系統軌跡紀錄查詢及管理頁面、資訊服務採購契約、系統作業手冊	P29
1-2	資訊單位系統紀錄檔，是否有定期 (_____ 一次) 備份轉出檔案後保存。	磁帶存放紀錄表、紀錄檔備份紀錄	P33
1-3	資訊單位是否有專人隨時 (經常) 檢視。	資訊室業務職掌表、系統紀錄檔查檢紀錄與相關簽文	P34
2. 系統存取異常狀況情形：			
2-1	系統登入次數是否正常 (相較一般使用習慣，系統登入次數小於 _____ 次)。	系統查詢軌跡紀錄檔 (以下同)、登入次數統計表	P35
2-2	系統登入失敗次數是否正常 (相較一般使用習慣，連續失敗次數小於 _____ 次)。	帳號認證及鎖定機制、登入失敗次數統計表	P36
2-3	登入系統查詢時段是否正常 (例如於正常勤務時間登入系統)。	查調人員差勤紀錄、非上班時段登入清單	P37
2-4	使用者系統連線電腦設備網際網路協定 (IP) 位址，是否正常 (例如 IP 位址為使用者公務慣用之位址)。	系統開放網域清單、帳號登入 IP 位址清單	P38
2-5	使用者之帳號密碼是否有共用或交由他人使用情形。	共用帳號清冊及主管批准簽文、帳號登入 IP 位址清單	P39
2-6	是否以離 (休) 職員工帳號登入使用之情形。	人事室離 (休) 職及異動同仁清冊、使用者帳號及權限管理規定、系統存取控制管理程序書、離職帳號權限刪除紀錄	P40
2-7	單次使用系統時間是否正常 (相較一般使用習慣，單次使用系統時間小於 _____ 小時)。	比對使用者帳號登入及登出間隔時間	P41
2-8	累計使用系統時間是否正常 (相較一般使用習慣，每月使用系統累計時間小於 _____ 小時)。	系統使用時間統計表	P41
2-9	使用者查詢筆數是否正常 (相較一般使用習慣，每月查詢筆數小於 _____ 筆)。	使用者查詢筆數統計表	P42
2-10	使用者是否依規定於查詢系統登載「案號」或「查詢事由」。	系統使用作業手冊及規範、檢視本項目是否為系統強制輸入事項	P43
2-11	系統雖無法登載「案號」或「查詢事由」，是否另設置「電腦查詢資料登記簿」管制使用情形。	系統查詢紀錄清冊、系統查詢登記簿	P43
2-12	使用者「查詢內容」與登載之「案號」(如收文號) 或「查詢事由」是否相符。	查調案件案卷資料勾稽比對	P43
2-13	系統存取系統管理者 (含系統委外維護廠商之管理者) 查詢筆數是否正常 (例如每月查詢筆數小於 _____ 筆)。	系統管理者查詢筆數統計表	P44
2-14	是否以機關首長、時事名人、公眾人物及其他特定之姓名為查詢條件情事 (亦即確認查詢作業係基於公務需要)。	建立查詢條件名冊進行勾稽	P44
2-15	是否有指派專人定期查核機關內使用者正常查詢機敏性資料系統，並留存查核紀錄備查。	業務職掌表、例行查核紀錄簽文	P44
3. 系統存取異常狀況通報情形：			
3-1	是否依機關需求界定或修訂系統存取異常狀況。	說明上述項目適用情形及有無自訂項目	P45
3-2	是否建立系統存取異常狀況通報機制且定期 (_____ 一次) 通報政風單位。	事件通報與應變管理程序書、例行查核作業簽文	P45



自資通安全管理法於 107 年 5 月 11 日經立法院三讀通過，並於 108 年 1 月 1 日施行至今，行政院資通安全處陸續推動各項資安防護政策，訂定資安維護計畫，召開會議及說明會，辦理資安人力職能訓練，並藉由各項子法修訂，完善我國資安法制架構，以求建立安全完善的數位環境。

根據現行的政府組織章程，機關安全維護責任歸屬於各機關政風人員，且資訊稽核向來是維護作業的重要工作項目，然而外界卻持續有政風人員專業度的質疑聲音，外行領導內行，是現行政府體制下的資安矛盾。

為協助各機關（構）強化資通安全管理機制，防範公務機密外洩，確保資料、系統、設備及網路安全，法務部廉政署自 108 年起即推動各政風機構以協助機關推動資訊使用管理稽核為重點，落實資訊安全維護。

本處為強化本府所屬各政風機構辦理資通安全防護工作，提升資訊使用管理稽核之完整性及有效性，特編纂本冊指引，從稽核觀念的闡析、法制相關規定、案例分析，到資訊使用稽核管理的實作項目，希盼能強化政風人員的專業素養，進而成為機關資安防護的重要利器。



目錄

稽核小知識

- 資訊稽核說明
- 法規依據
- 稽核要領
- 常用資安名詞彙編
- 案例研析
- 資通安全等級

資訊使用管理稽核

- 評估機關系統風險
- 擬定稽核計畫
- 建置系統查詢軌跡紀錄檔
- 界定異常存取情形及建立通報機制
- 異常存取自動化勾稽工具
- 召開研商會議及起始會議
- 稽核項目與稽核方法

資訊安全稽核

- 稽核項目
- 導入資訊安全管理系統 (ISMS) 情形
- 資安專責人員與認知訓練
- 存取權限與人員管理
- 個人資料保護
- 資訊資產管理
- 資訊委外安全管理

109 年本府稽核結果

- 概述
- 系統使用現況分析
- 權限管理情形
- 異常情形分析
- 缺失態樣
- 建議事項

壹、稽核小知識



資訊稽核說明

一、資訊安全稽核

資訊安全稽核，係由各機關資訊單位主導，針對機關之資訊安全管理，包括資訊資產管理、人員安全、實體安全、網路安全及系統安全等環節，並結合資通安全管理系統 ISMS 認證項目，進行全方面檢視。依稽查方之不同，可分為第一方稽核（組織內部）、第二方稽核（客戶、委外廠商）及第三方稽核（外部組織）。

二、資訊使用管理稽核

資訊使用管理稽核，係由各機關政風室主導，資訊單位提供技術支援，關注的層面為系統存取，主要稽核項目為系統查詢軌跡紀錄檔保存情形、系統存取異常情形、建立異常狀況通報機制。辦理時機得併同前述資訊安全稽核作業，亦得由政風室自行簽報計畫辦理。

三、兩者區分

易言之，「資訊使用管理稽核」只是「資通安全稽核」的一個環節，卻是政風人員維護機關資訊安全的重要工作。

表 1. 資訊稽核比較表

項目／名稱	資訊安全稽核	資訊使用管理稽核
主責單位	資訊單位	政風單位
稽核重點	技術面	異常存取情形
辦理法源	資通安全管理法及本府相關資通安全規範	臺北市政府及所屬各機關辦理資訊使用管理稽核作業規定

法規依據

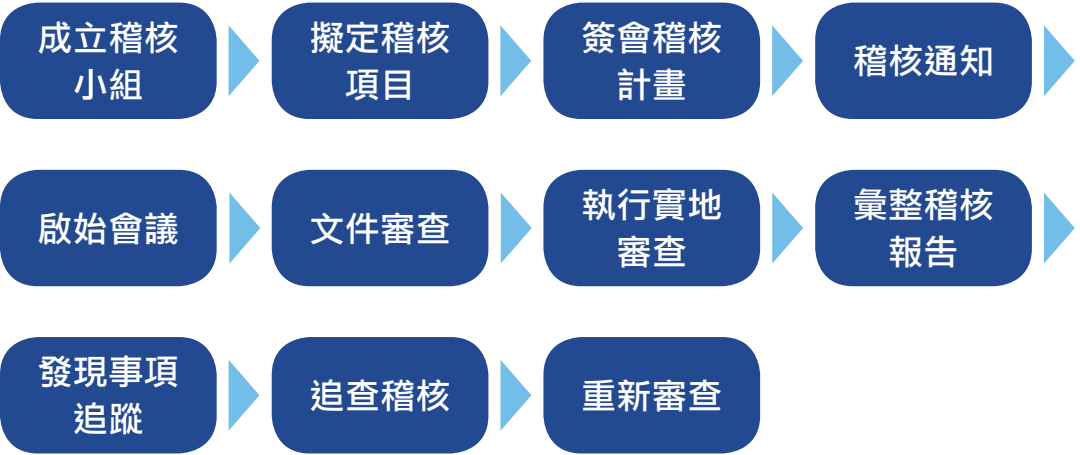
法規名稱	QR code
資通安全管理法	
資通安全管理法施行細則	
資通安全責任等級分級辦法	
附表九資通系統防護需求分級原則	
附表十資通系統防護基準	
資通安全事件通報及應變辦法	
資通安全管理法及子法彙編	
資通安全管理法常見問題	

法規依據

法規名稱	QR code
行政院及所屬各機關資訊安全管理要點	
臺北市政府資訊安全管理規範	
臺北市政府及所屬各機關辦理資訊使用管理稽核作業規定	
臺北市政府員工使用電腦應注意事項	
政風機構維護公務機密作業要點	
政風機構協助機關（構）推動資訊使用管理稽核實施計畫	
個人資料保護法暨施行細則	

稽核要領

一、稽核流程



二、稽核缺失類別

主要不符合事項 (Major Nonconformity)	1. 管理制度、程序、或控制措施的完全失效或未執行 2. 極高數量缺失事項集中某一控管點或單位 3. 重大資訊安全風險並未被鑑別及檢討改善 4. 存在明顯立即資訊安全損失的風險
次要不符合事項 (Minor Nonconformity)	1. 管理制度中某一特定的要求並未被履行 2. 違反管理安全政策、規範、管理要點、程序之要求 3. 違反系統程序或工作程序指示
觀察事項 (Observation)	1. 較輕微之缺失事項 2. 欲查核但目前無紀錄可進行查核之事項 3. 無直接證據指出為次要不符合事項，但予以記錄，於半年或一年後持續觀察
改善機會 (Opportunity for Improvement)	1. 建議未來可持續改進之事項 2. 改善管理系統有效性之建議措施

三、稽核手法

(一) 人員訪談
有效溝通
5W1H 原則



(二) 問卷
適合量化
結合訪談



(三) 文件紀錄查核
事前提供
風險控制



(四) 自動化工具
簡化稽核
建置經費

常用資安名詞彙編

名詞	說明
系統存取控制	定義是「對於資訊系統的存取保護，防止任何未經授權的系統存取、破壞。」於 ISO 27001:2013 中的項目包括：存取控制政策、網路與網路服務的存取、使用者存取管理、機密授權資訊的使用、系統與應用系統的存取控制。
CIA 資安鐵三角	Confidentiality (機密性)- 避免資料未經授權之存取或披露 Integrity (完整性)- 確保資訊之正確性及完整性 Availability (可用性)- 授權的使用者可以正常、可靠的使用資訊
防毒軟體 Anti-virus Program	防毒軟體用於偵測、移除電腦病毒、電腦蠕蟲、和特洛伊木馬程式，通常含有即時程式監控辨識、惡意程式掃描和清除和自動更新病毒資料庫等功能
管理者 Admin	為 administrator 的縮寫，指對特定系統或應用程式有最高權限者，得使用新增、刪除或修改等功能。
黑名單 Blacklist	黑名單是電腦應用中常使用的存取控制方式之一，被列入黑名單的用戶無法進入系統。如電郵過濾透過黑名單，阻擋某些電郵地址或伺服器發出的電郵，達到過濾垃圾郵件的目的。
白名單 Whitelist	與黑名單相對的是，即「除名列於上者外一律不准進入」的信任許可名單。
使用者記錄文檔 Cookies	指某些網站為了辨別用戶身分而儲存在用戶端 (Client Side) 上的資料，通常經過加密處理。
虛擬私人網路 VPN	虛擬私人網路 (VPN) 是一種常用於連接中、大型企業或團體與團體間的私人網路的通訊方法。它利用隧道協定 (Tunneling Protocol) 在使用者電腦和 VPN 閘道器之間建立加密通道，來達到傳送端認證、訊息保密與準確性等功能。

名詞	說明
防火牆 Firewall	在計算機科學領域中是一個架設在網際網路與企業內網之間的資安系統，根據企業預定的策略來監控往來的傳輸。主要功能為隔離網路，透過將網路劃分成不同的區域，制定出不同區域之間的存取控制策略來控制不同信任程度區域間傳送的資料流。
靜態應用軟體安全檢測 Static Application Security Testing	屬於「應用系統網站弱點掃描」的一種，亦常稱為靜態應用系統安全測試、白箱測試、源碼檢測，用不同角度檢查應用系統的原始碼(source code) 程式流中可能被攻擊者所發現的漏洞，優點：在在開發階段及早修復問題，比起事後修補容易。
GCB 政府組態基準 (Government Configuration Baseline)	目的在於規範資通訊設備（如個人電腦、伺服器主機及網通設備等）的一致性安全設定（如密碼長度、更新期限等），以降低成為駭客入侵管道，進而引發資安事件之風險。
資訊安全管理系統 ISMS (Information security management system)	是一套有系統地分析和管理的資訊安全風險的方法，有助於從法遵的合規性、技術及管理的有效性來對資訊安全進行評估。
ISO 27001:2013 資訊安全管理國際標準	目前國際上最廣泛採用之資訊安全管理規範，可提供建立、實作、運作、監視、審查、維持及改進資訊安全管理系統之模型，並可透過公正獨立的第三方組織，進行稽核與驗證
金鑰 KEY	在電腦技術中，是指一種與加密演算法搭配使用的符號序列，用於資料加 / 解密。
P2P 對等式網路 (peer-to-peer)	又稱對等技術，是無中心伺服器、依靠用戶群（peers）交換資訊的網際網路體系。透過減少網路傳輸節點，能降低資料遺失的風險，卻也相對造成監控的難度，且為病毒媒介、駭客入侵與洩密管道，形成資安破口。



名詞	說明
滲透測試 Penetration testing	伺服器／主機作業系統、應用軟體、網路服務、物聯網設備等，類比駭客的手法進行滲透或穿透跳躍主機之入侵測試，設法取得未經授權之存取權限，並測試內部資訊是否有遭受不當揭露、竄改或竊取之可能性。 「滲透測試」是由具備極高技術水準的資安顧問以人工方式模擬駭客的思維，針對系統做攻擊測試。國際常用的測試規範有 OWASP Checklist、OWASP ASVS、CWE/SANS Top 25 等。
紅隊演練 Red Teaming	係用以補足傳統滲透測試容易忽略之邊界防禦，以及基於人為疏失之佈署盲點，利用公開資訊、社交網路、暗網等蒐集目標情資，結合資訊安全專家之專業知識、攻防技術及駭客工具資料庫，對於雙方所約定之攻擊目標與組織，採取無所不用其極的方法進行入侵演練，同時可驗證防守方（藍隊）的偵測與回應能力。
伺服器 Server	對使用者端提供特定服務的硬體（Hardware）和軟體（Software）整合起來稱為「伺服器（Server）」。 可區分為管理資源並為用戶提供服務的電腦軟體，通常分為檔案伺服器（能使用戶在其它電腦存取檔案），資料庫伺服器和應用程式伺服器。或執行以上軟體的電腦，又稱為網路主機（host）。
社交工程 Social Engineering	係利用人性弱點，應用簡單的溝通和欺騙技倆，以獲取帳號、通行碼、身分證號碼或其他機敏資料，來突破資通安全防護，遂行其非法的存取、破壞行為。
SOC 資訊安全監控中心 (Security Operation Center)	資訊安全監控中心 SOC 管理組織的資安產品、網路設備、使用者設備，以及系統中任何可能違反資訊安全 CIA 的內容，提供 24*7 的服務負責監看，偵測與處理資安事故。



名詞	說明
SQL 注入 (SQL injection)	SQL 是一種資料庫系統常用的程式語言。若駭客在輸入的字串之中夾帶錯誤 SQL 指令，且程式忽略字元檢查，夾帶進去的惡意指令就會被資料庫伺服器誤認為是正常的 SQL 指令而執行，因此遭到破壞或是入侵，是發生於應用程式與資料庫層的安全漏洞。
SSL 加密通訊協定 (Secure Socket Laye)	傳輸層安全性協定（英語：Transport Layer Security，縮寫：TLS）及其前身安全通訊協定 SSL 是一種安全協定，目的是為網際網路通訊提供安全及資料完整性保障。
2FA 雙因素認證 (two-factor authentication)	認證，為確認是由本人所發出的，所以認證必須要有唯一性，不會重複。目前認證方式為：What you know ? (密碼或 PIN)、What you have ? (Token 或 Smart card)、What you are ? (生物特徵，如指紋)。雙因素認證，就是結合了兩種不同的認證方式，亦稱雙因子認證。 兩階段驗證（two-step verification），則是純粹的驗證過程有兩次，可以使用同一種認證方式驗證兩次，或是不同的認證方式。
弱點掃描 Vulnerability Assessment	「弱點掃描」是使用自動化工具對系統進行檢測，找出所有已知的風險。 弱點掃描分為系統弱點掃描與網站弱點掃描： 「系統弱點掃描」係針對作業系統的弱點、網路服務的弱點、作業系統或網路服務的設定、帳號密碼設定及管理方式等進行弱點檢測，系統弱點掃描的檢測項目須符合 Common Vulnerabilities and Exposures (CVE) 發布的弱點內容（最新版）。 「網站弱點掃描」係針對網頁安全弱點進行掃描，檢測項目須符合最新版 OWASP TOP 10。這種測試比較依賴程式本身的品質，不同廠牌、不同種類的規則，都會有不同的結果。



名詞	說明
UPS 不斷電系統 (Uninterruptible Power System)	是在電網異常（如停電、欠壓、干擾或浪湧「也稱：湧浪電流」）的情況下不間斷的為電器負載設備提供後備交流電源，維持電器正常運作的設備。
WAF 網站應用程式防火牆	WAF 主要是用於是保護網站應用程式，透過監控網站傳輸的 HTTP 流量，比對病毒與惡意程式資料庫，過濾出可疑流量並拒絕惡意流量進入，保護網站免受駭客攻擊。
縱深防禦 Defense-in-Depth	指利用多層次的防禦技術來減緩不同類型的攻擊，常見項目有：防火牆、Web 應用程式防火牆、入侵偵測防禦系統、病毒與垃圾郵件過濾閘道系統、虛擬私有網路、存取控制、資安事件監控等。
DMZ 邊界網路 DeMilitarized Zone	係屬網路架構布置方案之一種，常被使用的架設方案，是在不信任的外部網路和可信任的企業網路外，建立一個面向外部網路的邏輯子網路，在受保護網路與外部網路之間，新增的網路，用於對外部網路的伺服器主機，可提供額外保護內部網路的安全層，有時亦稱為週邊網路。
Windows 更新服務 (Windows Server Update Services)	是微軟公司開發的一個電腦程式，它允許管理員管理已為微軟產品發布的更新和熱修復修補程式分發到企業環境中的電腦。WSUS 從微軟更新網站下載這些更新，然後分發它們到網路上的電腦。
目錄列舉 (Directory Listing) 功能	瀏覽網站未指定瀏覽內容時，會根據網站伺服器所提供的選項搜尋該目錄中的啟始頁面（如：index.html）。若應用程式開啟目錄列舉功能，當應用程式未找到設定檔所指定的啟始頁面，便會列出該目錄下的所有檔案和目錄。駭客可藉此得知目錄中的檔案與結構，並取得儲存資料庫連線等網站相關設定。



名詞	說明
資安健診	資安健診服務係透過整合各項資通安全項目的檢視服務作業，提供受檢單位資安改善建議，藉以落實技術面與管理面相關控制措施，以提升網路與資訊系統安全防護能力。 包括網路架構檢視（檢視之項目包含設計邏輯是否合宜、主機網路位置是否適當及現有防護程度是否足夠）、有線網路惡意活動檢視（封包監聽與分析、網路設備紀錄檔分析）、使用者端電腦檢視（更新檢視、組態設定檢視、電腦惡意程式或檔案檢視）、伺服器主機檢視（更新檢視、組態設定檢視、惡意程式或檔案檢視）及安全設定檢視（目錄伺服器（如 MS AD）組態設定檢視、防火牆連線設定）等。
ISO 四階文件	第一階文件：主要包括全範圍之資安整體實行政策及原則，如：資安政策、管理手冊、適用性聲明等。 第二階文件：主要包括各領域之執行方向及原則，如：資訊資產、實體環境、人員安全、網路安全、風險評鑑、營運管理、系統開發、事件通報、內部稽核等程序書。 第三階文件：主要為包括相關業務流程及處理程序之詳細描述，如：人員職權、帳號及通行碼管理、備份、營運計畫、資料庫管理、委外人員管理等作業程序或辦法。 第四階文件：主要包括業務運作所採用之表單、合約及其產生之各項紀錄，如：文件記錄、衡量指標表、季報表、名冊、切結書等表單。
入侵偵測系統 IDS （Intrusion Detection System）	指通過對行為、安全日誌或稽核資料或其他網路上可以獲得的資訊，進行研判、比對，然後檢測出資料庫中入侵系統的異常行為或侵入的企圖
入侵預防系統 IPS （Intrusion Prevention System）	是一部能夠監視網路或網路裝置的網路資料傳輸行為的計算機網路安全裝置，能夠即時的中斷、調整或隔離一些不正常或是具有傷害性的網路資料傳輸行為。比較簡單的解釋是入侵預防系統 = 入侵偵測系統 + 防火牆。

案例研析

一、某機關電腦及公務信箱遭駭客入侵

（一）案例大要：

某縣市政府於 108 年間，疑似遭駭客利用 AD 派送客製化惡意程式到特定單位，進行資料竊取，並為躲避追查，抹除受駭系統稽核紀錄。

（二）手法分析：

1. 某機關透過防毒軟體偵測到多台電腦存在 APT（進階持續攻擊）惡意程式，將使用者所「開啟」的文件上傳到 google drive。
2. 同仁電腦遭植入惡意程式，駭客掌握電子郵件信箱的帳號密碼，並利用網頁郵件（WebMail）登入使用者帳號，設定郵件轉寄，藉以取得相關郵件往來資訊。
3. 機關在伺服器的系統記憶體中發現惡意程式以注入記憶體之攻擊方式，使各家防毒軟體幾乎無法掃描發現，並更改防毒軟體等主機之路由設定表（Routing Table），將連主機的路由器指向主機自己，導致掃描結果無法回傳，增加比對難度。
4. 駭客入侵維運系統主機，掌握系統管理者帳號及密碼，以帳號連線市府 VPN 主機，將廠商帳號預設通知信箱竄改，再以管理者帳號遠端登入備用防毒主機。
5. 本案發現共同特徵是無線路由器遭駭客開啟 VPN 功能，建立 VPN 帳號及虛擬伺服器，駭客使用工具掃描有漏洞之無線路由器，利用國人並無更新無線路由器韌體之習慣，進行攻擊。

（三）機關防處作為：

1. 依契約約定裁罰維運廠商，修訂維運工作標準作業程序，改善維運工作檢核表，導入特權帳號管理系統，強化密碼管理及側錄操作紀錄。
2. 針對重要核心主機，全面盤點網路連線，並導入 GCB 安全組態。
3. 針對維運人員工作站進行實體隔離，將遠端管理改為跳板主機方式管理。
4. 按月依監控數據、情資及架構等資訊調整 SOC 規則，並將核心設備相關安全日誌納入 SOC 監控機制與日誌系統。
5. 補強骨幹或機敏網路區域偵測設備，將曾出現的惡意程式更新至防毒系統病毒碼。
6. 持續強化公務電子信箱，增加 APT 惡意程式防護阻擋機制，關閉自動轉寄功能並提升加密傳輸方式。
7. 收容全部公務電子郵件系統，集中執行資安防護與監控管理。
8. 辦理紅隊演練（Red Team Assessment；在不影響營運前提下進行模擬入侵攻擊）。

（四）小結：

目前許多駭客中繼站之上層攻擊來源 IP 多來自中國網軍駭客組織所為，主要蒐集我國政府之人事、政策規劃、科研計畫及智庫資料，請各政風機構協調機關相關單位落實管理者帳號保管及強化密碼管理，確實掌握維運廠商的管理及資安狀況，持續檢視機關資安作為之執行情形，以有效防範駭客以公務電子郵件進行社交工程攻擊等情事。

二、某機關伺服器主機遭駭客入侵案例

（一）案例大要：

本府某機關伺服器於 109 年間遭駭客入侵，下載惡意工具並插入資料表，嘗試以持續性連線及漏洞工具進行後續攻擊。

（二）手法分析：

1. 駭客利用 SQL 注入攻擊伺服器中舊網站語法漏洞並開啟 XP_CMDSHELL 功能取得控制權。
2. 主機資料庫帳號之密碼為弱密碼，駭客取得帳號權限後下載惡意工具，藉此進行進一步攻擊。
3. 駭客於資料庫插入資料表，內容皆為系統錯誤訊息。

（三）機關防處作為：

1. 重新檢視並移除該伺服器網站資料夾內無使用之檔案，防止駭客利用舊網頁之漏洞進行攻擊。
2. 以讀取資料庫權限最小之帳號執行對外連線，避免資料庫遭竄改或破壞。
3. 每季變更所有資料庫密碼，且須符合複雜度及資安規範，並留存紙本紀錄備查。
4. 要求系統維護廠商每季提供各系統弱點掃描報告，如有發現中、高級以上問題，即時完成修補作業。
5. 開啟 SQL 稽核紀錄功能，以利未來資安事件調查使用。

（四）結語：

機關所屬閒置或不再使用之資訊系統、網站，資安措施或維護管理可能未盡完善，進而成為資安漏洞及攻擊目標，提醒各機關確實依資通安全責任等級分級辦法第 11 條第 2 項規定清查機關所使用網站與系統，並落實相關資安防護措施。



三、機關網站公開機密文書

（一）案情摘要：

某機關承辦人認所承辦之機密文書內容僅係函釋法令說明，實質上未涉及機敏性，逕行將該機密文書公告於機關網站，惟查該機密文書解密條件尚未成就，亦未辦理解密程序，爰依臺北市政府文書處理實施要點規定，仍應辦理保密措施。

（二）涉及法規：

1. 刑法第 132 條第 1 項。
2. 臺北市政府文書處理實施要點第 71 點、第 72 點、第 85 點第 1 項第 3 款及第 4 款。

（三）改進措施及建議作法：

1. 機關應加強宣導機密文書保密概念及洩漏公務機密責任，避免因法治概念認知不足，致罹刑章。
2. 機密文書受文機關如認該機密文書無保密之必要，仍應依臺北市政府文書處理實施要點第 85 點第 1 項第 3 款及第 4 款規定完成解密程序。
3. 機關網站資料公告應有審核機制或公告作業程序進行把關，以免影響機關形象。

四、透過某搜尋網站可下載本府員工薪資資料

（一）案情摘要：

某機關人員於入口網站搜尋機關新聞，發現可查詢本府員工薪資資料，經查該系統建置年代較久，資安防護較弱，且系統主機置於 DMZ 區，雖有設置使用者帳號密碼登入機制，且系統查詢資料連結原僅有系統使用者可得知，卻因為該搜尋網站將個人搜尋紀錄與公開搜尋結果混合，使外界可透過該搜尋網站連結至表單。

（二）涉及法規：

1. 刑法第 318 之 1 條、第 359 條。
2. 個人資料保護法第 16 條、第 18 條、第 28 條。

（三）改進措施及建議作法：

1. 設置系統防火牆及存取控制白名單。
2. 下載報表資料程序，設置帳號密碼機制或防止螢幕輸出等安全控管機制。
3. 老舊系統資安防護不足，重新盤點機關老舊系統並進行健診，檢測是否存有資安風險；針對具大量個資之系統進行滲透測試，依檢測結果進行改善修補。

五、學生個資誤傳學校網站

（一）案情摘要：

透過搜尋引擎，可下載某校學生個資（姓名、班級、身分證字號、生日、聯絡方式等個人資料），查係該校於網站之最新消息公告中，不慎夾帶含有學生個資之檔案，另該網頁目錄瀏覽功能未關閉，任何人均可透過瀏覽目錄取得機敏資料。

（二）涉及法規：

1. 個人資料保護法第 18 條、第 28 條。
2. 臺北市政府資訊安全管理規範第 19 點第 5 項。

（三）改進措施及建議作法：

1. 機關網站資料公告應有審核機制或訂定作業程序進行把關，以免影響機關形象。
2. 檢視機關網站之網頁瀏覽目錄權限是否為關閉狀態，避免公務機密或民眾個資外洩。
3. 將機關伺服器移至上級機關或本府資訊局集中統一管理，提升資安防護措施，樽節資安相關經費。

資通安全責任等級

臺北市政府暨所屬各機關構（含各級學校及幼兒園）之資通安全等級，依行政院 108 年 6 月 14 日核定函及後續修正（每兩年檢討一次），各級機關數量分布如下圖

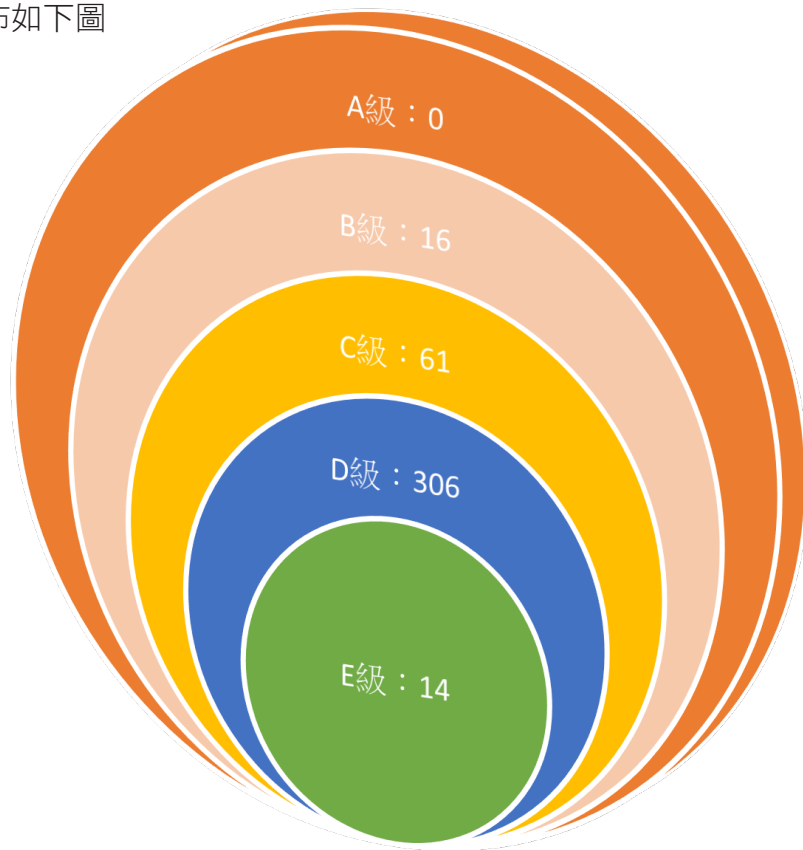


圖 1. 本府各級機關（構）資安等級分布同心圓

A級機關：本府無

B級：警察局、衛生局、稅捐處等

C級：工務局、產發局、大安區公所等

D級：政風處、其他區公所等

E級：各幼兒園

貳、資訊使用管理稽核



評估機關系統風險

辦理資訊使用管理稽核起手式，為審視機關主要業務項目，從中檢視業務單位使用哪些核心資訊系統，哪些是機關自主、委外開發系統或是介接外機關資料庫？各系統使用作業管理要點或手冊是否有相關稽核規定？茲提供幾項判斷要點供分析判斷：

表 2. 系統風險評估指標表

檢視項目	範例或內容	檢視情形
機關業務有無涉及區域性或地區性之關鍵基礎設施事項	水費水表營收系統、水庫水文監測系統、交通監控系統	
機關業務有無涉及查詢民眾大量個人資訊之資料庫	地方稅務系統、戶役政系統、不動產地籍系統	
是否每年有中央目的事業主管機關定期考核系統使用情形	警政署－警政知識聯網、財政部－稅務系統、內政部－戶役政及地籍系統	
調閱系統盤點清冊加以瞭解機關使用系統概況	資訊系統安全等級、是否為共用性系統、承辦（管理）單位及維運廠商	
針對前述特定系統調閱安全等級評估表	影響構面、等級評估及原因說明	
就選定系統，調閱系統資訊安全稽核規定（或資訊安全政策、系統作業手冊等）	瞭解稽核頻率、範圍及方法等	

擬定稽核計畫

依臺北市政府及所屬各機關辦理資訊使用管理稽核作業規定第 5 點第 2 款，稽核計畫得包含下述內容：

表 3. 資訊使用管理稽核實施計畫表

臺北市政府○○局處 ○○年度資訊使用管理稽核實施計畫	
項目	內容說明
壹、依據	參考本冊法令規定章節及各資訊系統使用稽核規定。
貳、目的	為保護本處機敏營運資料、提升服務品質、強化資訊安全管理、提升機關重視資安程度、通盤檢視法規面、制度面、執行面之運作情形等。
參、稽核時間	執行稽核期間，通常以年度為主。
肆、稽核範圍	某區間之系統查詢相關紀錄。
伍、稽核人員編組	政風室會同資訊室成立內部稽核小組，政風室辦理幕僚作業，資訊室負責稽核技術支援及提供紀錄資料。
陸、受稽核單位及人員	系統管理者、使用單位及人員。
柒、稽核方式（作業程序）	調閱相關系統查詢紀錄表冊等文件，比對民眾申請書、公文等查調依據，依稽核項目表逐一比對檢視，或採線上抽查，稽核比率應符合一定比率，得事先採使用單位自檢方式，以提升實地稽核之效率。
捌、稽核項目	詳如後述
玖、結果處理	依稽核情形填具稽核結果報告，陳核後，送請相關科室做為業務策進之參考並追蹤缺失改善情形，另循政風體系陳報上級機關政風室及本府政風處。
拾、保留條款	本計畫如有未盡事宜，得隨時修正。

建置系統查詢軌跡紀錄檔

在電腦領域，系統查詢軌跡紀錄檔（Log file）是一個記錄了發生在執行中的作業系統或其他軟體中的事件의檔案，許多作業系統、軟體框架和程式都包含紀錄檔系統。廣泛使用的一項紀錄檔標準是 **syslog**，使專門的標準化子系統得以生成、過濾、記錄和分析紀錄檔訊息。相關說明詳見本冊「稽核項目與方法（一）」。

依「政風機構協助機關（構）推動資訊使用管理稽核實施計畫」第 5 條第 1 項，工作內容如下：

表 4. 系統查詢軌跡紀錄檔工作項目表

項次	工作內容
1	系統應建置、啟動、處理及保留使用者紀錄檔，如紀錄檔資料不足以作為稽核管理使用，得協調另行開發或購置進階之管理工具。
2	系統查詢軌跡紀錄檔應處於啟動狀態，並應定期備份轉出檔案後保存，使其具有連貫性，以作為日後調查及監督之用。
3	系統查詢軌跡紀錄檔應指定專人定期及日常檢視，並做成書面紀錄備查。
4	應依規定確保使用者紀錄檔之建置與保存，俾利查察違規使用、越權查閱、下載資訊等異常情事，並就資通安全漏洞研採補救與防範措施，以及追究相關法律或行政責任，以有效防止公務機密資訊外洩。

界定異常存取情形及建立通報機制

界定異常存取情形及建立異常通報機制之目的，是為篩選可能存有缺失之查詢項目，以提升抽樣及實地稽核之效率，並於事件發生當下可即時處理，**並非指異常存取情形即為缺失項目**，仍需請使用者說明並提供查詢依據佐證，未符規定者始能認定為缺失項目。

依政風機構協助機關（構）推動資訊使用管理稽核實施計畫第 5 條第 2 項，得就機關（構）現有資通系統特性及運作現況，界定以下例示之系統存取異常狀況及建構相關通報機制，並協調資訊單位即時或按月彙送系統存取異常狀況報表供政風機構進行瞭解：

表 5. 異常存取情形項目表

異常項目	內容
系統登入	例如系統登入（失敗）次數異常頻繁、於非勤務時間登入系統、登入系統連線之電腦設備網際網路協定 (IP) 位址異常、使用他人或離（休）職員工帳號登入等異常狀況。
使用時間	例如相較於一般使用習慣，單次使用系統時間或累計使用系統時間異常增加等情形。
查詢異常	例如查詢筆數異常頻繁、未於系統登載「案號」或「查詢事由」，亦未設置「電腦查詢資詢登記簿」、「查詢內容」與登載之「案號」或「查詢事由」不符、具系統存取特別權限者查詢筆數異常頻繁、以機關首長、時事名人或公眾人物之姓名為查詢條件等異常狀況。
其他系統存取異常狀況	查調三親等親屬資料、假日進行資料主檔或資料庫內容異動等

異常存取自動化勾稽工具

機關是否設置系統自動化勾稽程式，應視系統屬性、中央機關授權情形及機關實際需要而訂：

1. 資訊系統依開發及管理方之不同，可分為共同性系統與自主系統，前者可再細分如下：¹
 - (1) **共用性系統**指單一機關主責系統開發與資料管理，其餘機關僅涉及使用操作，可能無權取得自動分析之數據，只能產出查詢紀錄明細，如國稅系統。
 - (2) **共通性系統**指單一機關主責系統開發與規格制訂，其餘機關除使用操作外，資料主要儲存於使用機關，如公文電子交換系統。
2. 機關自行開發或委外開發之系統，建置系統存取異常即時通報的自動化工具，於技術面上是可行的，難處可能在於建立自動化程式的預算費用、使用單位與資訊單位的配合度及日後程式維護管理的人力等。
3. 故各政風室應與機關相關單位審慎評估系統資料查詢使用情形、管理面及實際需要，研議是否建置自動化工具，或以人力取代之，畢竟使用稽核管理重點還是在於整體異常存取制度之建立、管理與異常情事之釐清。

¹ 依資訊系統分級與資安防護基準作業規定四、處理步驟說明

異常存取自動化勾稽工具

實務範例：

本府警察局資訊室針對系統部分，以自行研發「警政日誌巨量資料分析系統」過濾有無不當查詢本局同仁（含幹部、女性）、時事名人、委託查詢未填理由、非勤務時間查詢、查詢排行榜（含同仁查詢量、熱蒐證號、車號、姓名、查詢外籍人口）等查詢紀錄，並提供相關資料予政風室稽核。

圖 2. 警政日誌巨量資料分析系統介面圖



召開研商會議及起始會議

政風室應會同使用、管理及稽核單位三方，針對前述機關風險評估、稽核計畫擬定及異常存取項目之界定等，召開研商會議，共同磋商尋求共識。

先簽會資訊使用管理稽核計畫，或是先召開研商會議，得視機關慣例由政風室自行衡酌考量。簽會計畫在前可讓首長及機關同仁事前透過書面資料瞭解相關資訊，幫助研商會議快速達成共識，更可適時運用機關局處務會議、廉政會報或安全維護會報機制，提高機關首長及同仁對稽核的重視度。

起始會議（行前會議）著重於稽核執行面的操作，就稽核人員及受稽對象，確認細部稽核範圍、稽核方法與項目、稽核所需文件、工作分配等，提升實地稽核的效率。

稽核項目與稽核方法

依法務部廉政署 108 年 2 月 23 日廉政字第 10807003420 號書函檢送「政風機構協助機關（構）推動資訊使用管理稽核項目表（參考範本）」，各政風機構得視機關（構）實際狀況增刪稽核項目，並結合各機關（構）現有之資通安全稽核表併同辦理，茲以範本項目進行說明：

政風機構協助機關（構）推動資訊使用管理稽核項目表（參考範本）					
項次	項目名稱	查核結果 □符合 □不符合 □部分符合 □不適用	查核情形 (簡述符合、部分符合、不符合或不適用之原因)	紀錄文件	處理情形或改善措施

（一）系統查詢軌跡紀錄檔 (Log)：

1.1	資訊單位是否有建立及啟動系統查詢軌跡紀錄檔 (Log)，並保存一段時間（保存多久？），以作為日後調查及監督之用。
-----	--

因應資訊安全與法規要求，現行各機關使用之資訊系統多已建立及啟動系統查詢軌跡紀錄，然而是否達到規定要求之內容及完整性，必須再由同仁詳細檢視。有關稽核紀錄之措施內容如下：²

表 6. 稽核紀錄措施項目表

措施內容	說明	檢視情形
稽核事件	1. 依規定時間週期及紀錄留存政策，保留稽核紀錄。 2. 確保資通系統有稽核特定事件之功能，並決定應稽核之特定資通系統事件。 3. 應稽核資通系統管理者帳號所執行之各項功能。 4. 應定期審查稽核事件。	
稽核紀錄內容	1. 資通系統產生之稽核紀錄應包含事件類型、發生時間、發生位置及任何與事件相關之使用者身分識別等資訊，並採用單一日誌紀錄機制，確保輸出格式之一致性。 2. 資通系統產生之稽核紀錄，應依需求納入其他資訊。	
稽核儲存容量	依據稽核紀錄儲存需求，配置稽核紀錄所需之儲存容量。	
稽核處理失效之回應	1. 資通系統於稽核處理失效時，應採取適當之行動。 2. 機關規定需要即時通報之稽核失效事件發生時，資通系統應於機關規定之時效內，對特定人員提出警告。	

² 依資通安全責任等級分級辦法第 10 條第 2 項及附表十資通系統防護基準規定之稽核與可歸責性構面

措施內容	說明	檢視情形
時戳及校時	1. 資通系統應使用系統內部時鐘產生稽核紀錄所需時戳，並可以對應到世界協調時間 (UTC) 或格林威治標準時間 (GMT)。 2. 系統內部時鐘應依機關規定之時間週期與基準時間源進行同步。	
稽核資訊之保護	1. 對稽核紀錄之存取管理，僅限於有權限之使用者。 2. 應運用雜湊或其他適當方式之完整性確保機制。 3. 定期備份稽核紀錄至與原稽核系統不同之實體系統。	

另有關系統查詢軌跡紀錄檔之保存時間，資通安全管理法及子法未有具體規定，而是散見於各資訊系統管理法規，如臺北市不動產數位資料庫系統作業規範、國稅地方稅資訊交流運用系統作業手冊均規定查詢紀錄需保存 2 年。另機關自主開發之系統，得於遵循前述措施內容之原則下，依業務性質及同仁使用需求，自行訂定紀錄檔保存時間。

部分由機關自行招標委外設置之資訊系統，應正確使用行政院公共工程委員會訂頒之「資訊服務採購契約範本」或本府相關資訊契約範本，並注意契約文件應明文要求廠商保存並指派專人稽核系統之使用軌跡紀錄，以符資訊類採購案之需求及特性。

參考文件：系統作業手冊或內部規定、系統軌跡紀錄查詢及管理頁面（如下圖）、系統查詢紀錄清冊、資訊系統採購契約

實務範例：

編號	啟始時間	結束時間	連線時間	來源IP	流量	結束原因
1	2020-07-17 09:25:58		0秒	114.114.10.10	_IN: 0 B OUT: 0 B	
2	2020-07-16 18:00:01	2020-07-17 05:44:11	42252秒	114.114.10.10	_IN: 89.91 MB OUT: 13.77 MB	Lost-Carrier
3	2020-07-16 14:37:07	2020-07-16 17:14:30	9445秒	114.114.10.10	_IN: 76.12 KB OUT: 10.92 KB	Lost-Carrier
4	2020-07-16 14:29:06	2020-07-16 14:35:10	366秒	114.114.91.91	_IN: 15.45 KB OUT: 1.14 KB	Lost-Service
5	2020-07-15 21:18:15	2020-07-16 14:23:45	61532秒	125.125.216.216	_IN: 4.92 MB OUT: 19.62 MB	Lost-Service
6	2020-07-15 18:37:24	2020-07-15 21:17:52	9630秒	125.125.216.216	_IN: 2.77 MB OUT: 9.58 MB	Lost-Carrier
7	2020-07-15 10:14:36	2020-07-15 18:37:13	30159秒	125.125.216.216	_IN: 11.52 MB OUT: 58.33 MB	Lost-Carrier
8	2020-07-15 09:54:39	2020-07-15 10:13:50	1153秒	125.125.216.216	_IN: 299.09 KB OUT: 1.28 MB	Lost-Carrier
9	2020-07-14 18:16:28	2020-07-15 09:20:00	54215秒	125.125.216.216	_IN: 499.55 KB OUT: 1 MB	Lost-Carrier
10	2020-07-14 15:19:53	2020-07-14 16:17:44	3473秒	61.261.6.6	_IN: 3.09 MB OUT: 6.29 MB	Lost-Carrier
11	2020-07-14 11:58:07	2020-07-14 15:19:11	12066秒	61.261.6.6	_IN: 4.01 MB OUT: 7.78 MB	Lost-Carrier
12	2020-07-14 09:47:35	2020-07-14 11:57:25	7792秒	61.261.6.6	_IN: 4.15 MB OUT: 12.19 MB	Lost-Carrier
13	2020-07-14 09:23:39	2020-07-14 09:47:03	1406秒	61.261.6.6	_IN: 861.65 KB OUT: 6.67 MB	Lost-Carrier
14	2020-07-14 05:27:14	2020-07-14 09:23:13	14162秒	61.261.6.6	_IN: 100.63 KB OUT: 13.86 KB	Lost-Carrier

圖 3. 教育局教網中心系統查詢紀錄軌跡介面圖



圖 4. 地政局資訊系統登入紀錄查詢頁面

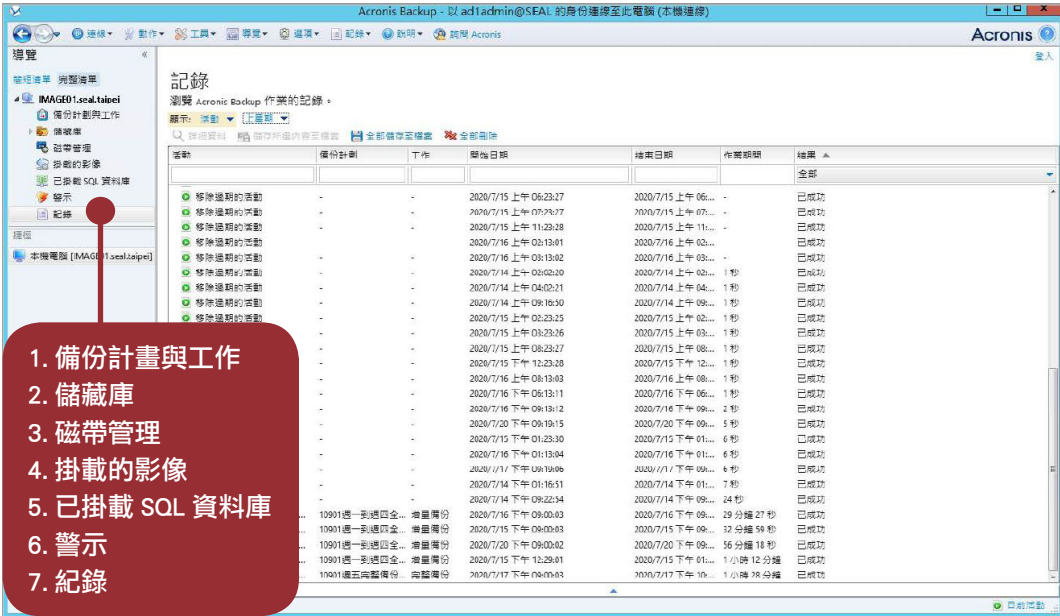


圖 5. 民政局資訊系統資料庫備份畫面

1.2 資訊單位系統紀錄檔，是否有定期備份轉出檔案後保存。

為避免駭客入侵、系統電腦中毒造成檔案毀損及遺失，致影響機關業務正常營運，機關應定時備份系統資料庫方式，包含系統軌跡紀錄檔，並以實體（磁帶、硬碟、備份機）、異地及離線方式，避免連結網際網路，滋生二次資安風險。

就資訊系統錄檔之保存方式有直接以正式機保存、使用磁碟陣列儲存系統 (NAS)，甚或是由系統維護管理之中央機關先保存，地方使用機關再定期下載存取，均無不可。

參考文件：磁帶存放紀錄表（如下圖）、備份紀錄

文件類別	內部使用	磁帶存放紀錄表	文件編號
版次	V1.0		ISMS-4-007-05-1-109002

填寫月份：2月

備份磁帶資料日期	存放日期	捲數	簽名	備份磁帶資料日期	存放日期	捲數	簽名
1	2	1	楊	16	17	1	楊
2	3	1	吳	17	18	1	楊
3	4	1	吳	18	19	1	吳
4	5	1	楊	19	20	1	吳
5	6	1	楊	20	21	1	楊
6	7	1	吳	21	22	1	楊
7	8	1	吳	22	23	1	吳
8	9	1	楊	23	24	1	吳
9	10	1	楊	24	25	1	楊
10	11	1	吳	25	26	1	胡
11	12	1	吳	26	27	1	吳
12	13	1	楊	27	28	1	吳
13	14	1	楊	28	29	1	楊
14	15	1	吳	29	31	1	楊
15	16	1	吳				

管理人員 股長

圖 6. 自來水事業處磁帶存放紀錄表

1.3 資訊單位是否有專人隨時（經常）檢視。

此處**專人**非指**資通安全專職人員（詳如後述）**，而係指特定人員之職務內容包含管理及檢視系統查詢軌跡紀錄檔者。機關系統數量較多或組織規模較大者，各使用單位得設置管理者先行檢視單位內部稽核紀錄檔資料，再定期陳報予機關主要管理人員進行彙整。

稽核人員得調閱資訊單位業務職掌表，瞭解管理人員及職務代理人之配置，詢問該同仁就前述項目之辦理情形、自主查核及定期檢視之頻率，並查看簽核紀錄，確認逐次保存及備份人員是否確實為該同仁。

須特別留意，此處專人應儘量避免由系統使用者擔任，以免發生球員兼裁判之情事。

參考文件：資訊室業務職掌表、系統紀錄檔查檢紀錄與相關簽呈

（二）系統存取異常狀況情形：

2.1	系統登入次數是否正常（相較一般使用習慣，系統登入次數小於____次）。
-----	-------------------------------------

各機關得依下列指標綜合檢視，歸納出一般使用習慣：

表 7. 系統登入次數異常指標表

指標	說明
同仁業務性質	依業務性質差異，如為後台承辦作業人員（第二線），同仁登入系統查詢完資料即可登出，登入次數較多；又如為受理民眾洽公櫃台人員（第一線），上班時段同仁會維持系統上線以提高服務速度，登入次數較少。
單一入口平台介接	如單一入口平台介接系統數較多，又無依個別系統計數，則帳號登入次數較多。
系統穩定度	如果系統負載量較低（與伺服器頻寬、記憶體容量、硬體設備相關），時常斷線易造成系統登入次數較高。
有無設定閒置時間自動下線機制	如系統有設定閒置 30 分鐘下線機制，則登入次數較多。
查詢資料屬性	簡易查詢資料之系統，登入次數較多；須線上作業之系統，登入次數較少。

部分使用共用系統之機關，如稅捐稽徵處，僅能產出系統查詢紀錄報表，無法記錄及統計使用者登入數據（累積登入次數、單次使用時間、累積在線使用時間等），故不適用之。

範例：自來水事業處針對水費水表營收系統 3 個月超過 500 次、停車管理工程處針對第三代公路監理系統每日超過 5 次為異常。

2.2

系統登入失敗次數是否正常（相較一般使用習慣，連續失敗次數小於 ____ 次）。

按常理，連續登入系統失敗次數超過 3 次即屬異常情形；較長區間之異常登入失敗次數，得依前項系統登入次數需求推算。

另為防止有心人士以惡意重複登入程式猜測密碼，系統應具備帳戶鎖定機制，帳號登入進行身分驗證失敗達三次後，至少十五分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗驗證機制，³ 且帳號遭鎖定後需聯繫系統管理者始能解鎖或更改密碼。於此情形雖不適用此項目，惟稽核人員仍可對該機制詳加描述；若資訊系統未設定帳戶鎖定機制者，應利用稽核時機與相關單位研議是否設置。

範例：自來水事業處水費水表營收系統連續登入失敗次數 5 次；停車管理工程處第三代公路監理系統連續登入失敗 3 次；稅捐稽徵處係使用自然人憑證登入財稅內網，PIN Code 連續輸入錯誤 3 次即鎖卡。

參考文件：帳號認證及鎖定機制、2FA 雙因素認證

³ 依資通安全責任等級分級辦法附表十資通系統防護基準之識別與鑑別構面規定

2.3

登入系統查詢時段是否正常（例如於正常勤務時間登入系統）。

各機關得依下列指標綜合檢視，歸納出一般使用習慣：

表 8. 系統查詢時段異常指標表

指標	說明
同仁加班情形	適逢業務旺季，如地方稅稽徵月份，或單位人力短缺增加現有人力作業量，均會增加同仁加班機率，容易出現異常時段查詢情形。
同仁業務性質	依業務性質差異，如為後台承辦作業人員，較易有加班情形；又如為受理民眾洽公櫃台人員，於正常洽公時間才會登入系統。
機關輪班需求	如警察、消防機關等業務性質，同仁須全天候 24 小時輪值者，則需透過勤務分配表檢視。

為民服務機關可擇定平日上午 8 時至下午 18 時以外之時段（包含假日，並扣除補班日），為異常查詢時段，再依前述指標做調整。

參考文件：系統使用查詢時段分析、查詢人員差勤紀錄

2.4

使用者系統連線電腦設備網際網路協定 (IP) 位址，是否正常 (例如 IP 位址為使用者公務慣用之位址)。

機關應設定系統使用者 IP 位址之白名單，限制使用者登入網域，並使用 IP 管理與網路存取控制工具 (例如 Arpro) 進行管控，避免查詢權限人員藉由非經授權許可之設備裝置、網際網路位址登入系統，形成系統資安漏洞。

亦有部分系統，如民政局戶役政系統，使用者只能經由中央目的事業主管機關核准之 IP 位置連線查詢，故使用機關管理者應注意同仁調 (異) 動情形，落實帳號及時異動作業；若部分機關未能從源頭控管 IP 連線，至少必須於查詢紀錄軌跡檔 (Log file) 確實記錄所有系統查詢者之 IP 位置，以利事後追蹤。

對於允許遠端存取之資訊系統，使用者帳號均應先取得授權，定義存取控制點，建立使用限制、組態需求、連線需求及文件化，且使用者之權限檢查作業應於伺服器端完成，並應監控資通系統遠端連線情形及採用加密機制。⁴

參考文件：系統開放網域清單

⁴ 資通安全責任等級分級辦法第 10 條第 2 項及附表十資通系統防護基準規定之遠端存取措施內容

2.5

使用者之帳號密碼是否沒有共用或交由他人使用情形。

資通系統應具備唯一識別及鑑別機關使用者之功能，禁止使用共用帳號，目的為使系統查調人員權責分明，包含約聘僱人員、職工及其他臨時人員。資訊系統可採用 2FA 雙因素認證機制，如登入系統需同時使用自然人憑證及帳號密碼，避免遭他人誤盜用帳號情形。⁵

若機關有特別規定准許得使用共用帳號者，使用同仁應提出正當理由申請經主管核准，且管理者應定期清查共用帳號使用情形，查看有無未授權使用者登入情事。

稽核方法包括：核對系統授權使用人員名冊及單位現有人員名冊、調閱系統登入軌跡紀錄檔以清查同一帳號登入 IP 位址有無異動，並請同仁提供差勤紀錄、輪值表、簽到使用紀錄進行交叉比對，若機關有共用公務電腦 (如輪值服務櫃台) 或同仁異動頻繁者，更應落實帳號管理措施。

參考文件：系統登入軌跡紀錄檔、共用帳號清冊

⁵ 資通安全責任等級分級辦法第 10 條第 2 項及附表十資通系統防護基準之內部使用者之識別與鑑別措施內容

2.6 是否沒有以離（休）職員工帳號登入使用之情形。

閒置久未登入、已逾期之臨時或緊急帳號應刪除或禁用。帳號管理機制，包含帳號之申請、開通、停用及刪除之程序，應有效建立並落實執行。⁶

機關同仁辦理離職或職務異動手續時，離職報告單應併同權限帳號異動單簽會資訊室，再由系統管理者即時辦理帳號異動作業，並可設定權限帳號管理系統連動人事資料管理系統，以利即時更新在職人員名冊，刪除非在職同仁之存取權限。

系統管理單位應定期辦理帳號清查作業，檢測有無離職同仁帳號尚未刪除，並產出逾期多日未登入之使用者清單，請使用單位檢視該帳號有無繼續保留需要。

稽核方式得向人事室調閱正式員工及約聘雇同仁近期離退職紀錄，比對資訊室產出之系統離職權限刪除異動紀錄表冊，檢視系統管理單位是否有同仁離職多日而帳號未刪除情形。

參考文件：使用者帳號及權限管理規定、系統存取控制管理程序書

⁶ 依資通安全責任等級分級辦法附表十資通系統防護基準之帳號管理措施內容

2.7	單次使用系統時間是否正常（相較一般使用習慣，單次使用系統時間小於 ____ 小時）。
2.8	累計使用系統時間是否正常（相較一般使用習慣，每月使用系統累計時間小於 ____ 小時）。

各機關得依下列指標綜合檢視，歸納出一般使用習慣：

表 9. 系統使用時間異常指標表

指標	說明
同仁業務性質	依業務性質差異，如為後台承辦作業人員，同仁登入系統查詢完資料即可登出，系統使用時間較短；如為受理民眾洽公櫃台人員，上班時段同仁會維持系統上線以提高服務速度，系統使用時間較長。
單一入口平台介接	如單一入口平台介接系統數較多，又無依個別系統計數，則系統使用時間較長。
系統穩定度	如果系統負載量較低（與伺服器頻寬、記憶體容量、硬體設備相關），時常斷線易造成系統使用時間較長。
有無設定閒置時間自動下線機制	如系統有設定閒置 30 分鐘下線機制，則使用時間較短。
查詢資料屬性	簡易查詢資料之系統，使用時間較短；須線上作業之系統，使用時間較長。

範例：停車管理工程處針對第三代公路監理系統以單次使用時間大於 1 小時、每月使用系統類計時間大於 100 小時為異常。

使用共用系統之機關可能不適用之。多數機關無法界定或檢測此項目，惟仍建議系統可設定使用者登入一定時間未操作者，會自動登出下線功能，減少遭他人誤盜用帳號之可能。

2.9	使用者查詢筆數是否正常（相較一般使用習慣，每月查詢筆數小於 ____ 筆）。
-----	--

各機關得依下列指標綜合檢視，歸納出一般使用習慣：

表 10. 查詢筆數異常指標表

指標	說明
同仁業務性質	依業務性質差異，如為後台承辦作業人員，使用者查詢筆數較少；如為受理民眾洽公櫃台人員，查詢筆數較多。
系統穩定度	如果系統負載量較低（與伺服器頻寬、記憶體容量、硬體設備相關），時常斷線易造成查詢失敗次數較多，查詢次數也較多。
查詢資料屬性	簡易查詢資料之系統，查詢次數較多；須線上作業之系統，查詢次數較少。
同仁加班情形	適逢業務旺季，如地方稅稽徵月份，或單位人力短缺增加現有人力作業量，均會增加同仁加班機率，容易出現查詢筆數異常情形。

透過檢視查詢筆數異常情事，可瞭解有無同仁大量蒐集個資作不法用途，亦或是外界有心人士利用系統漏洞滲入擷取資料。

範例：自來水事業處以 3 個月超過 20000 筆為異常，停車管理工程處以每月使用查詢筆數大於 700 筆為異常。

2.10	使用者是否依規定於查詢系統登載「案號」或「查詢事由」。
2.11	系統雖無法登載「案號」或「查詢事由」，是否另設置「電腦查詢資料登記簿」管制使用情形。

系統是否須設置登載「案號」或「查詢事由」機制，應視系統主管機關法規、業務性質是否單純及機關首長權責決定。

本項雖非強行規定，但要求登記案號或查詢事由能有效減少同仁恣意查詢之動機，也利於事後追查管理，另有部分機關要求同仁查詢資料前要逐筆經主管陳核在案，更能強化查調前審查作業。

針對民眾、民代電話或現場查詢、臨時交辦案件、未立案或誤查案件等無相關申請單或公文可資證明者，建議設置「系統查詢登記簿」俾利事後追蹤。

參考文件：系統查詢紀錄清冊、系統查詢登記簿

2.12	使用者「查詢內容」與登載之「案號」（如收文號）或「查詢事由」是否相符。
------	-------------------------------------

沒有特別訣竅，就是調閱資料勾稽比對。依系統使用軌跡紀錄查詢內容，請使用單位提供相關案卷資料，如民眾申請單、機關公文、主動稽查之文件列冊，由稽核人員比對查詢內容與查調依據，確認同仁查詢目的係屬公務查詢用途，並釐清有無誤載誤查案件。

政風單位可推動使用單位自檢作業，由單位管理人員先行檢視，最後再由稽核人員依比率抽查或全面清查，以提高實地稽核之效率，並建立異常通報機制。

2.13 系統存取特別權限者查詢筆數是否正常（例如每月查詢筆數小於____筆）。

使用者帳號依存取權限大小差異，區分為特權使用者和一般使用者，前者如系統管理者、網管、資料庫管理者、應用程式開發人員，以及 IT 系統與設備中預設的管理者共用帳號，還有應用程式本身執行時的專用存取帳號等，亦可能由開發、維護系統廠商持有。

資訊稽核對象通常都只針對一般使用者，對特別權限者則缺乏監督，又其職務內容特殊，較少辦理人民申請案件或他機關索資案件，而是需要下載或傳輸大量資料予中央主管機關，極易形成資安死角及駭客下手目標。

對於特別權限者難以訂定通用稽核項目，惟建議稽核人員可先鎖定對象，再依其業務職掌擬定防弊措施。

2.14 是否沒有以機關首長、時事名人或公眾人物之姓名為查詢條件情事（亦即確認查詢作業係基於公務需要）。

首先應建立機關首長、時事名人或公眾人物之名單，再據以訂定相關查詢條件，併同 2.12 項目辦理稽核作業。

2.15 是否有指派專人定期查核機關內使用者正常查詢機敏性資料系統，並留存查核紀錄備查。

描述使用單位內查核人員、系統管理單位或政風室之稽核頻率及稽核情形，有無定期彙整相關紀錄檢陳主管核章備查。

參考文件：稽核紀錄文件

（三）系統存取異常狀況通報情形：

3.1 是否符合機關需求界定或修訂系統存取異常狀況。

前述項目是否符合機關系統需求？針對受稽系統歷年缺失情形，有無訂定其他存取異常狀況？

其他系統存取異常範例：頻繁登入系統卻未執行查詢或操作、假日時段進行系統資料異動、有臨時人員使用系統情形、同仁針對三親等內親屬進行資料異動等，亦可將內部資通安全稽核中機關常見缺失項目，列入稽核項目表。

3.2 是否建立系統存取異常狀況通報機制且定期通報政風單位。

針對前述異常狀況項目，當使用單位或資訊室發現有異常情事時，有無即時通報或定期簽會政風室之機制，如每月由資訊單位釐清各使用單位自檢情形後簽會政風室，或是必須由政風室定期辦理稽核始能勾稽異常情事。

參考文件：事件通報與應變管理程序書



參、資訊安全稽核

稽核項目

一、法規未訂定明確稽核項目

資通安全管理法及子法屬原則性規範，未詳細敘明資通安全稽核需函括哪些必要稽核項目，各資安權責機關得參考資通安全管理法施行細則第 6 條資通安全維護計畫應包括事項，以及資通安全責任等級分級辦法第 9 條各級機關應辦事項，自訂稽核項目表，並視每年度行政院資安會報之稽核重點作適時調整。

二、行政院辦理 108 年公務機關資安稽核項目

行政院為協助各機關強化資通安全防護工作之完整性及有效性，並透過持續改善提升資安防護水準，行政院國家資通安全會報於網際防護體系下設「資通安全防護組」，自 90 年起每年選定重要機關辦理資安外部稽核。

108 年公務機關資安稽核概況報告之稽核基準與項目，經參酌國際資訊安全管理標準 ISO 27001、國際資訊服務技術管理標準 ISO 20000、行政院及所屬各機關資訊安全管理要點、個人資料保護法及資安法等，據以規劃，如下表：



表 11. 行政院 108 年公務機關資安稽核項目表

108 年公務機關資安稽核概況報告－稽核項目表			
第 1 階段：技術檢測 本項檢測在檢驗機關安全組態設定及安全性更新之落實度		第 2 階段：實地稽核	
檢測項目	檢測子項	實地稽核分策略面、管理面及技術面等 3 個構面	
使用者電腦安全檢測	使用者電腦弱點掃描 使用者電腦安全防護檢測	策略面	導入資訊安全管理系統範圍之適切性
網路惡意活動檢視	惡意中繼站連線阻擋檢測		機關首長對資安業務之支持度
核心資訊系統安全檢測	核心資通系統內網滲透測試 核心資通系統防護基準檢測		資源投入資安業務狀況
網路架構檢測	網域主機安全防護檢測		資安業務運作規劃與落實
網域主機安全防護檢測	網域主機安全防護檢測	管理面	資產管理與風險管理
物聯網設備檢測	網路攝影機、門禁設備、網路印表機、無線網路基地台 / 無線路由器、環控系統檢測		人力資源管理
			資訊作業委外安全管理
			所屬機關監督管理（上級 / 監督機關適用）
組態設定安全檢測	作業系統組態、瀏覽器組態、網通設備組態、應用程式組態檢測	技術面	電子資料保護
			通訊與作業安全
			資安事件通報與處理
			資訊系統開發與維護安全

三、臺北市政府資訊使用管理稽核項目

為強化本府資訊系統資料運作及資安防護機制，落實個人資料保護法及公務機密保護相關規定，防止發生機敏性資料、個資不當使用或外洩情事，爰針對本府建置使用民眾個人資料較頻繁、近期曾發生資安事件或遭攻擊頻率較高之機關，評估該機關資安管理實施成效。

本次資訊使用管理稽核項目，經參考相關法規，訂定如下，並就第一大項擇選政風協助檢視細目進行說明。：

表 12. 本府 109 年度資訊使用管理稽核項目表

本府 109 年度資訊使用管理稽核項目表
1. 機關資訊安全防護基準（依「資通安全責任等級分級辦法」規定，各責任等級之公務機關應辦理資訊安全措施）
2. 資通系統防護基準
3.Windows 伺服器安全基準檢核
4.SQL Server 資料庫安全基準檢核
5.Linux 伺服器安全基準檢核
6. 個人電腦安全基準檢核
7. 資訊系統存取情形
8. 委外廠商查核（含資訊安全、個資管理）

導入資訊安全管理系統 (ISMS) 情形

1.1	是否規劃並訂定符合機關（構）需要之資訊安全管理系統適用範圍？以及未納入適用範圍部分之理由為何？是否定期檢視其適切性？
-----	--

依資通安全責任等級分級辦法 11 條，各機關應依其資通安全責任等級，辦理附表一至附表八之事項，

資安等級 A、B、C 級機關應於初次受核定或等級變更後之二年內，將全部核心資通系統導入 CNS 27001 或 ISO 27001 等**資訊安全管理系統標準**、其他具有同等或以上效果之系統或標準，或其他公務機關自行發展並經主管機關認可之標準，並持續維持導入。

依施行細則第七條規定之核心資通系統，係指滿足任一條件者（支持核心業務運作必要之系統或資通系統防護需求等級為高），都為核心資通系統；資通系統之性質為共用性系統者，由該資通系統之主責設置、維護或開發機關判斷是否屬於核心資通系統。。

A、B 級機關另外需完成公正**第三方驗證**作業，另 D、E 級機關無自行或委外開發之資通系統，故無需導入 ISMS。第三方指通過我國標準法主管機關經濟部委託財團法人全國認證基金會 (TAF) 認證之機構，名單如下：

表 13. 第三方驗證機構清冊

認證編號	第三方驗證機構 - 認可公司清冊
MS001	臺灣檢驗科技股份有限公司（SGS）
MS004	香港商英國標準協會太平洋有限公司台灣分公司（BSI）
MS012	艾法諾國際股份有限公司（afnor）
MS013	環奧國際驗證有限公司（TCIC）
MS014	香港商漢德技術監督服務亞太有限公司台灣分公司（TUV NORD）

1.2	核心資訊系統是否依資安責任等級分級應辦事項納入資訊安全管理系統 (ISMS) 適用範圍？
-----	--

依資通安全責任等級分級辦法附表九及十，各機關自行或委外開發之資通系統應依所定資通系統防護需求分級原則完成資通系統分級，並依資通系統防護基準執行控制措施，產製**資訊系統清冊**。

特別強調，因為有時資訊系統也會被列入資訊設備作管理，然而**資訊系統清冊與資訊資產清冊**並不相同，前者結合系統評估表，注重資訊系統安全等級的評定，後者則重視資產設備之實際使用管理情形（詳見本章節項目 5）。參考表單如下：

表 14. 資訊系統清冊

臺北市政府○○局資訊系統清冊								填寫日期： 年 月 日			
編號	資訊系統名稱	業務屬性	資訊系統安全等級	共同性系統 (Y/N)	承辦 (管理單位)	系統承辦人	系統廠商	連絡電話	輔導時間	安全等級評估表狀態	資通系統防護基準自評表狀態
承辦人：			復核主管：			資安長：					

表 15. 資訊系統安全等級評估表

○○○系統安全等級評估表				
功能說明：		業務屬性： ☐ 業務類 ☐ 行政類		
影響構面				資通系統安全等級
1. 機密性	2. 完整性	3. 可行性	4. 法律遵循性	

步驟一：設定影響構面等級

影響構面		安全等級	原因說明
1. 機密性	初估		
	異動		
2. 完整性	初估		
	異動		
3. 可用性	初估		
	異動		
4. 法律遵循性	初估		
	異動		

步驟二：識別業務屬性

項目		業務屬性	原因說明
1. 識別業務屬性	初估		
	異動		
2. 是否為共用性系統	初估		
	異動		
系統承辦人：		資安承辦人：	承辦單位主管：

資安專責人員與認知訓練

2.1	是否遵循資安責任等級分級應辦事項相關規定，指定專責人員負責資訊安全管理系統之維護與檢討，並有適切分工？
2.2	是否指定專人或專責單位負責資訊服務請求 / 事件處理、維運及檢討，並有適切分工？

資通安全專職人員，指應全職執行資通安全業務，意即渠業務職掌及工作內容不可辦理一般行政庶務，且具有登入國家資通安全通報應變網站帳號權限者。

依資通安全責任等級分級辦法，資通安全專責人員，各級機關應設置人數：A 級機關 4 人，B 級機關 2 人，C 級機關 1 人，D、E 級機關未規定，細部職務執掌工作項目則視資訊室分工情形辦理。

相關參考文件：資訊安全組織名冊、資訊室工作分配表、維運廠商契約等。

2.3	人員是否瞭解機關之資訊安全政策，以及應負之資安責任？是否依職務層級辦理適當之資訊安全認知教育與訓練？
2.4	人員是否遵循資安責任等級分級應辦事項相關規定，接受資安專業課程訓練、資安職能訓練及資安宣導？

依資通安全責任等級分級辦法應辦事項，各級機關資通安全專職人員、資訊人員、一般使用者及主管，均有一定資通安全專業課程訓練或資通安全職能訓練時數之要求規定：

表 16. 各級機關資通教育訓練要求時數表

認知與訓練構面要求						
人員區分 / 機關分級		A 級機關	B 級機關	C 級機關	D 級機關	E 級機關
資通安全專職人員	資通安全教育訓練	每人每年至少接受 12 小時以上之資通安全專業課程訓練或資通安全職能訓練			未規定	
	資通安全專業證照	初次受核定或等級變更後之一年內，總計應持有 4 張以上。	初次受核定或等級變更後之一年內，總計應持有 2 張以上。	總計應持有 1 張以上。		
	資通安全職能評量證書	初次受核定或等級變更後之一年內，總計應持有 4 張以上。	初次受核定或等級變更後之一年內，總計應持有 2 張以上。	初次受核定或等級變更後之一年內，總計應持有 1 張以上。		
其他資訊人員		每人每 2 年至少接受 3 小時以上之資通安全專業課程訓練或資通安全職能訓練，且每年接受 3 小時以上之資通安全通識教育訓練。				
一般使用者及主管		每人每年接受 3 小時以上之資通安全通識教育訓練				

一般使用者及主管，係指除包含機關組織編制表內人員外，尚包含得接觸或使用機關資通系統或服務之各類人員（院臺護字第 1090003579 號函）。

資通安全專業課程訓練或資通安全職能訓練相關時數，可透過以下方式取得⁷：

- 1. 參加經行政院資通安全處認證之資安訓練機構舉辦之資安職能訓練。
- 2. 參加技服中心舉辦之政府資通安全防護巡迴研討會，或所開設之資通安全管理、技術相關課程。
- 3. 參加資通安全專業證照清單⁸上所列之訓練課程。
- 4. 參加國內外之公私營訓練機構所開設或受委託辦理之資通安全管理或技術訓練課程。

參考文件：人力資訊安全管理程序書、新進同仁系統使用須知、共通性系統權限申請表、網路資源保密及使用切結書。

⁷ 相關內容詳見行政院國家資通安全會報技術服務中心 - 資安人才培訓服務網 <https://ctts.nccst.nat.gov.tw/>

⁸ 清單按季更新，詳見行政院國家資通安全會報網站－資安法專區－資安管理法，<https://nicst.ey.gov.tw/Page/EB237763A1535D65>

存取權限與人員管理

3.1

是否訂定人員之資訊安全作業程序與權責？是否明確告知保密事項，且簽署保密協議？

依公務員服務法第 4 條保密義務規定，各機關多要求新進同仁於報到當日簽署保密協議，填妥系統權限開通申請書等文件，機關並應儘速辦理新人訓練，俾利新進同仁瞭解機關資訊安全規定，內容可參考下圖。

新進人員資安宣導單(範本)

- 資安宣導：密碼換新、程式更新、下載要當心。(機關可自行填寫資安宣導)
- 辦公環境內必須使用機關提供之資訊設備、網路，及規定之軟體，不得使用個人私有設備及中國廠牌產品，公務設備亦不得連結個人私有手機上網。若有業務上的需求，必須經資安長同意後，列冊管理並定期檢討。
- 上班期間不應連結非公務需要之網站，並避免連結惡意網站或釣魚網站，如發現異常連線，請通知資安窗口。
- 不得使用公務電子信箱帳號登記做為非公務網站的帳號，如社群網站、電商服務等。
- 公務資料傳遞及聯繫必須使用公務電子郵件帳號，不得使用非公務電子郵件傳送或討論公務訊息。
- 即時通訊軟體使用應注意不得傳送公務敏感資料。
- 傳送公務資訊應有適當保護，例如加密傳送。
- 帳號密碼必須妥善保存，並遵守機關規定，如有外洩疑慮，除儘速更換密碼外，並應通知資安窗口。
- 主動通報資安事件或可能資安風險者，依規定獎勵。
- 未遵守機關資安規定，初次予以告誡，若持續發生或勸導不聽者，依規定懲處；若因而發生資安事件，加重處分。
- 有資安疑慮或異常時，應即時通報資安窗口。
- 應遵守個人資料保護法及資訊安全管理法。
- 資安訊息網址：(機關資安宣導及規範網址)
- 資安窗口：
 - 姓名：
 - 電話：
 - 電子郵件：
- 宣導人：
新進人員簽名：
中華民國 年 月 日

本宣導單1式2份，由新進人員及宣導人各執1份

圖 7. 行政院資通安全處訂定新進人員資安宣導單（範本）

3.2

是否遵循存取權限最小化原則，僅授權因職務所需之存取權限，且定期審查其適當性與正確性？

最小權限原則是要求計算環境中的特定抽象層的每個模組如進程、用戶或者電腦程式只能訪問當下所必需的信息或者資源。賦予每一個合法動作最小的權限，就是為了保護數據以及功能避免受到錯誤或者惡意行為的破壞。

機關權限帳號管理者，應針對使用者業務性質，賦予不同存取權限且分別管理，避免共用帳號之情形，並定期辦理特殊權限及一般權限帳號清查，作成紀錄表單。

參考文件：帳號權限控管作業說明書、存取控制管理程序書、帳號清冊

3.3

是否針對人員（包含正式人員、臨時人員、派遣人員等）之離職或調職，訂定作業管理程序，且落實執行（如：帳號存取權限回收、停用或移除之處理等）？

帳號權限管理者應確實依員工離職報告單、帳號申請異動註銷單，註銷各項資訊資源及使用權限，若涉及單一簽入系統或人事系統聯動他系統者，並應注意有無一併刪除成功，帳號權限管理者並應按季辦理清查作業。

參考文件：權限帳號管理系統資訊作業規定、網域帳號清單、帳號申請異動註銷單。

個人資料保護與管理

4.1	是否明確界定個人資料範圍？是否針對個人資料檔案進行內 / 外部環境與作業流程分析，以鑑別與個資有關之流程或應用系統，且落實執行個資盤點？
4.2	檢視蒐集、處理或利用個人資料之流程中，是否依照法律規定以及內部管理程序進行？
4.3	是否建立個人資料安全管理安控機制？機制內容是否包含存取權限、資料安全、人員管理及設備安全管理等（如：個人資料之傳送是否採取加密等保護機密性、是否確保個人資料之完整性等）？
4.4	是否針對所屬人員進行認知宣導與教育訓練，並確實記錄？
4.5	是否針對個人資料相關設備進行安全管理（如：相關儲存媒體、設備是否有安全處理程序及分級標示、報廢程序等）？
4.6	是否建立個人資料安全稽核機制（包含對委外供應商之稽核，確保委外作業建立必要的個資管理流程、程序及安全控制措施等）？
4.7	是否建立個人資料使用紀錄、軌跡資料及證據保存相關管理機制（如新增、修改、刪除、資料匯出、列印等操作紀錄）？
4.8	具個人資料之系統是否有建立稽核機制？是否進行安全檢測作業（如滲透測試）？
4.9	於事故發生時，是否依規定通報，並作出應變處置及預防等措施？

公務機關對個人資料之**蒐集、處理及利用**，規定於個人資料保護法第 15 條至 18 條及施行細則第 23 至 25 條規定，其中本法第 18 條更規定，公務機關保有個人資料檔案者，應指定專人辦理安全維護事項；又同法施行細則第 12 條規定，本法所稱**安全維護措施**，指公務機關或非公務機關為防止個人資料被竊取、竄改、毀損、滅失或洩漏，採取技術上及組織上之措施，包含下述事項：

表 17. 個資法安全維護措施事項表

個人資料保護法施行細則第 12 條之安全維護措施	
1. 配置管理之人員及相當資源	2. 界定個人資料之範圍
3. 個人資料之風險評估及管理機制	4. 事故之預防、通報及應變機制
5. 個人資料蒐集、處理及利用之內部管理程序	6. 資料安全管理及人員管理
7. 認知宣導及教育訓練	8. 設備安全管理
9. 資料安全稽核機制	10. 使用紀錄、軌跡資料及證據保存
11. 個人資料安全維護之整體持續改善	

除個人資料範圍之界定及處理程序外，其他事項經常會併同資通安全管理法之公務機關應辦事項辦理。

個資盤點的意義在於，透過機關全面性的清查，鑑別出所有與個人資料相關之業務流程，根據法規要求個資之定義，檢視所有已蒐集之個人資訊，並針對各個流程細項瞭解其作業架構，資以判斷其相對應之風險，並施以適切的控制措施。此外，若**機關資訊系統未涉及個資者，則不適用之**。

經參考經濟部個人資料保護作業手冊，個資盤點表應含括項目如下⁹：

表 18. 個資盤點表

主要業務、職掌	細部作業名稱	個人資料檔案名稱	主管單位	保有單位	檔案形態	保有依據	是否告知	特定目的	個人資料類別	§ 17 對外公告
資料來源	內部傳送	外部傳送	委外	個人資料項目	特種個人資料	保管方式	保存期限	銷毀方式	備註	單位名稱

⁹ 填寫說明得參考經濟部法規委員會網站 - 經濟部個人資料保護作業手冊 109 年 4 月版

再提供政風室個資盤點表（財產申報審查業務）範例參考：

表 19. 財產申報審查業務個資盤點表

作業流程名稱		個人資料檔案基本資訊														
主流程名稱	子流程名稱	個人資料檔案名稱	檔案型態	當事人	保有依據	特定目的	個人資料類別						§ 17 對外公告			
政風	預防業務	公職人員財產申報審查	2. 電子類	同仁	公職人員財產申報法	○一四	C○○一, C○○二, C○二一, C○二二, C○三一, C○○三, C○二三, C○三二, C○一一						Y			
資料流																
組織身分		資訊來源	組織內部提供者		組織內部接收者		資料處理者		第三方		國際傳輸		組織身分補充欄位			
資料控制者		直接蒐集	各單位主管人員		N/A		N/A		法務部		N/A		法務部			
一般個資																
姓名	生日	身分證號	護照號碼	特徵	指紋	婚姻	家庭	教育	職業	聯絡方式	財務情況	社會活動	網路識別資料	定位資料		
Y	Y	Y	N	N	N	Y	Y	N	Y	Y	Y	N	N	N		
特殊類別個資					自訂高風險個資					其它可識別個資		保護方式	保存			
病歷	醫療	基因	性生活	健康檢查	犯罪前科	財產資料	所得資料	營業資料	納稅資料	其他直接識別	其他間接識別	控制措施	儲存位置	法定保存期限	自訂保存期限	銷毀方式
N	N	N	N	N	N	Y	Y	N	N	N	N	AD 帳密管控	個人電腦	N/A	業務存續期間皆保存	業務存續期間皆保存

相關參考文件：個資盤點清冊、個人資料蒐集處理及利用管理程序書、資安暨個資管理制度四階文件

資訊資產管理

5.1	是否確實盤點資訊資產並建立清冊（如：識別擁有者與使用者等）？是否訂定資訊分級規則（如：區分機密性、敏感性及一般性等）、授權處理層級及處理規範，且落實執行？
5.2	是否建立資訊資產異動管理程序，即時更新資訊資產清冊，且落實執行？
5.3	是否訂定資訊設備汰除管控程序，以確保清除資訊設備或儲存媒體內所存放之機敏資料，或將其實體破壞？

一般資訊資產管理內容如下：資訊資產驗收、盤點、保管與使用、分類、價值等級評估、編號及標示、歸還及報廢處置。

機關應每年至少進行乙次資產盤點與資訊資產清單覆核，以更新及確保資訊資產清單的正確性及完整性。**資訊資產清冊**通常包含以下項目：業務流程、資訊資產類別（資料文件、軟體、服務、人員、硬體及無形資產）、名稱說明、權責保管單位、資產價值評估、機密等級（一般、限閱、敏感、機密）等，範例如下：

表 20. 資訊資產清冊

資訊資產清冊												
資產名稱	大類別	小類別	單位名稱	擁有者（部門 / 職務 / 角色）	管理者（部門 / 職務 / 角色）	使用者（部門 / 職務 / 角色）	存放位置	資產說明	機密性	完整性	可用性	資產價值
滅火器 *2	建築與保護類	建築保護設施	政風處	○○○	○○○	○○○	庫房	二氧化碳滅火器	1	1	3	3
IBM 資料庫主機	硬體類	伺服器	政風處	○○○	○○○	○○○	機房	系統電腦主機伺服器	2	1	3	3

有關資訊資產異動程序，除定期清查作業以外之維護時機如下：資產有新增、汰除或更換時，機關組織、業務調整或作業流程有所變更時，或於機關調整 ISMS 驗證或實施範圍時。

有關資訊設備汰除管控程序，依臺北市市有財產報廢處理原則，針對使用年限屆滿之資訊設備或儲存媒體，常以格式化作業、物理實體破壞等方式移除內建公務資料後，視其殘餘價值，選擇以轉贈或洽一般廠商價購或交回收清除機構價購，或無償交由環保局資源回收車回收。

參考文件：資訊資產清冊、資產管理程序書、資產分類與控管程序書、個人電腦暨可攜式儲存媒體作業說明書、實體與環境安全管理程序書、資訊設備報廢管理作業說明書、財產異動 / 報廢單



5.4	機關是否尚有使用違害國家資通安全疑慮之產品？是否有造冊列管並評估汰換事宜？
-----	---------------------------------------

依各機關對危害國家資通安全產品限制使用原則，所稱**危害國家資通安全產品**，指對國家資通安全具有直接或間接造成危害風險，影響政府運作或社會安定之資通系統或資通服務，且不定限於中國生產或陸資企業製造商品。

各機關除因業務需求且無其他替代方案外，不得採購及使用前述產品。必須採購或使用時，應具體敘明理由，經主管機關核可後，以專案方式購置，並列冊管理及遵守下列規定：指定特定區域及特定人員使用、不得與公務網路環境介接、不得處理或儲存機關公務資訊、測試或檢驗結果應產出報告，且購置理由消失，或使用年限屆滿應立即銷毀。

受到規範的產品範圍則囊括：伺服器主機、網路攝影機、遙測定點設備、無人機、雲端服務、電信業的核心骨幹網路設備電腦軟體、防毒軟體、機關委外開發的軟體系統、委外通訊設備顧問，以及委外企業開發資訊系統等。

鑑於中央主管機關遲未公布危害國家資通安全產品廠商清單，本府資訊局盤點目前有疑慮之設備產品供各機關參採：

表 21. 目前有疑慮之設備產品

目前有疑慮之設備產品	
網路設備	TP-Link、TOTOLINK
通訊設備	ALCATEL
行動裝置	OPPO、HUAWEI、Coolpad、小米 Mi 系列
錄影監視系統	海康、大華



資訊委外安全管理

6.1 是否訂定廠商之資訊安全責任與保密規定？是否要求執行資安稽核，並請廠商提供異常報告，以利後續追蹤與管理？

鑑於時常有資安事件肇因於委外廠商而起，對於委外廠商之規範必須嚴格落實。

依本府資訊安全管理規範第 9 點第 3、4 款，資訊業務委外時，應於事前審慎評估可能之潛在安全風險，並與廠商簽訂適當之資訊安全協定，將安全管理責任相關事項納入契約條款。委外人員資訊系統使用權限應經適當控管；委外期間結束後，應立即收回該項權限。

機關辦理資訊系統委外招標案件時，可參考行政院國家資通安全會報技術服務中心之資訊系統委外開發 RFP 資安需求範本及行政院公共工程委員會之資訊服務採購契約範本或本府訂定之相關資訊系統安全共通規範，內述系統資訊安全需求及廠商遵循事項之規定。

參考文件：資訊作業委外服務安全作業要點、資訊委外業務派駐人員管理規範、資訊作業委外服務資訊安全需求、委外管理程序書、第三方管理程序書、系統建置 / 維護案契約、應用程式獲取開發及維護管理程序書、供應商關係管理程序書、保密切結同意書（如下圖）

保密同意書

茲緣於簽署人_____（簽署人姓名，以下稱簽署人）參與_____（廠商名稱，以下稱廠商）得標_____（機關名稱）（以下稱機關）資訊業務委外案_____（案名）（以下稱「本案」），於本案執行期間有知悉或可得知悉或持有政府公務秘密及業務秘密，為保持其秘密性，簽署人同意恪遵本同意書下列各項規定：

第一條

簽署人承諾於本契約有效期間內及本契約期滿或終止後，對於所得知或持有一切機關未標示得對外公開之公務秘密，以及機關依契約或法令對第三人負有保密義務之業務秘密，均應以善良管理人之注意妥為保管及確保其秘密性，並限於本契約目的範圍內，於機關指定之處所內使用之。非經機關事前書面同意，不得為本人或任何第三人之需要而複製、保有、利用該等秘密或將之洩漏、告知、交付第三人或以其他任何方式使第三人知悉或利用該等秘密，或對外發表或出版，亦不得攜至機關或機關所指定處所以外之處所。

第二條

簽署人知悉或取得機關公務秘密與業務秘密應限於其執行本契約所必需且僅限於本契約有效期間內。簽署人同意公務秘密與業務秘密，應僅提供、告知有需要知悉該秘密之履約廠商團隊成員人員。

第三條

簽署人在下述情況下解除其所應負之保密義務：
原負保密義務之資訊，由機關提供以前，已合法持有或已知且無保密必要者。
原負保密義務之資訊，依法令業已解密、依契約機關業已不負保密責任、或已為公眾所知之資訊。
原負保密義務之資訊，係自第三人處得知或取得，該第三人就該等資訊並無保密義務。

第四條

簽署人若違反本同意書之規定，機關得請求簽署人及其任職之廠商賠償機關因此所受之損害及追究簽署人洩密之刑責，如因而致第三人受有損害者，簽署人及其任職之廠商亦應負賠償責任。

第五條

簽署人因本同意書所負之保密義務，不因離職或其他原因不參與本案而失其效力。

第六條

本同意書一式叁份，機關、簽署人及_____（廠商）各執存一份。

簽署人姓名及簽章：

身分證字號：

聯絡電話：

戶籍地址：

所屬廠商名稱及蓋章：

所屬廠商負責人姓名及簽章：

所屬廠商地址：

中

華

民

國

年

月

日

圖 8. 資訊服務採購契約範本 - 廠商保密同意書

65



保密切結書

立切結書人_____（簽署人姓名）等，受_____（廠商名稱）委派至_____（機關名稱，以下稱機關）處理業務，謹聲明恪遵機關下列工作規定，對工作中所持有、知悉之資訊系統作業機密或敏感性業務檔案資料，均保證善盡保密義務與責任，非經機關權責人員之書面核准，不得擷取、持有、傳遞或以任何方式提供給無業務關係之第三人，如有違反願賠償一切因此所生之損害，並擔負相關民、刑事責任，絕無異議。

- 一、 未經申請核准，不得私自將機關之資訊設備、媒體檔案及公務文書攜出。
- 二、 未經機關業務相關人員之確認並代為申請核准，不得任意將攜入之資訊設備連接機關網路。若經申請獲准連接機關網路，嚴禁使用數據機或無線傳輸等網路設備連接外部網路。
- 三、 經核准攜入之資訊設備欲連接機關網路或其他資訊設備時，須經電腦主機房掃毒專責人員進行病毒、漏洞或後門程式檢測，通過後發給合格標籤，並將其粘貼在設備外觀醒目處以備稽查。
- 四、 廠商駐點服務及專責維護人員原則應使用機關配發之個人電腦與週邊設備，並僅開放使用機關內部網路。若因業務需要使用機關電子郵件、目錄服務，應經機關業務相關人員之確認並代為申請核准，另欲連接網際網路亦應經機關業務相關人員之確認並代為申請核准。
- 五、 機關得定期或不定期派員檢查或稽核立切結書人是否符合上列工作規定。
- 六、 本保密切結書不因立切結書人離職而失效。
- 七、 立切結書人因違反本保密切結書應盡之保密義務與責任致生之一切損害，立切結書人所屬公司或廠商應負連帶賠償責任。

立切結書人：
姓名及簽章 身分證字號 聯絡電話及戶籍地址

立切結書人所屬廠商：
廠商名稱及蓋章 廠商負責人姓名及簽章 廠商聯絡電話及地址

填表說明：
一、 廠商駐點服務人員、專責維護人員，或逗留時間超過三天以上之突發性維護增援、臨時性系統測試或教育訓練人員（以授課時需連結機關網路者為限）及經常到機關洽公之業務人員皆須簽署本切結書。
二、 廠商駐點服務人員、專責維護人員及經常到機關洽公之業務人員每年簽署本切結書乙次。

中 華 民 國 年 月 日

圖 9. 資訊服務採購契約範本 - 廠商人員保密切結書



6.2	委外廠商專案成員進出機關範圍是否被限制？對於委外廠商駐點人員使用之資訊設備（例如：個人、筆記型、平板電腦、行動電話及智慧卡等）是否建立相關安全管控措施？設備攜入/出有無填寫申請表？
-----	--

關於門禁及人員管制部分，委外廠商派駐人員應列冊管理，接受適任性審查，規劃資安及個資訓練課程，禁止廠商再分包，並規劃機關內部實體安全控管，限制人員進入安全敏感核心地點。

有關設備管理部份，人員攜帶資訊設備進出資訊機房時，須於「資訊機房人員進出管制紀錄」註明，若業務需要申請對外網路需依規定申請並經權責主管核准，並確認連線設備已安裝防毒軟體，其病毒碼更新狀態至最新，單純為儲存媒體應先經過安全掃描，確認無安全風險後始得攜入使用。

參考文件：廠商資訊業務委外服務團隊成員名冊、機關提供硬體設備一覽表、人員進出電腦機房管制簿、實體與環境安全管理程序書、可攜式電腦或媒體使用申請註銷單、資產分類與控管程序書。

6.3	是否訂定委外廠商系統存取程序與授權規定（例如：限制其可接觸之系統、檔案及資料範圍）？委外廠商專案人員調整與異動，是否依系統存取授權規定，調整其權限？
-----	--

委外駐點廠商原則依帳號權限控管暨存取控制作業辦理，如遇業務上有遠端連線需要時，廠商需透過 VPN 連線，並由機關資訊人員向資訊局申請相對應系統位址遠端連線，連線設定亦須經過本府加密網段追蹤，甫能存取指定之系統。應用系統委外開發或維護專案契約應訂有管理及終止契約相關條款。

參考文件：系統委外開發或維護專案契約、系統存取控制管理程序書。



肆、本府 109 年資訊使用管理稽核結果彙整

概述

本處 109 年度擇選本府機關業務涉及查調民眾大量個人資訊與使用頻率較高之資料庫，針對各機關核心資訊系統，辦理本年度資訊使用管理稽核作業，並撰寫本處 109 年資訊使用管理稽核報告。謹此就初步稽核結果簡要摘述及說明於後，供同仁參考運用。

本次稽核擇選機關及系統如下表：

表 22.109 年度本府資訊使用管理稽核擇選機關表

機關名稱	系統名稱
警察局	警政知識聯網資訊系統
社會局	社會福利資訊系統
教育局	主辦甄選試線上報名系統
地政局	臺北市不動產數位資料庫系統
交通局	第三代公路監理資訊系統
民政局	戶役政資訊系統
稅捐稽徵處	全國財產總歸戶查詢系統
自來水事業處	水費水表營收系統

系統使用現況分析

統計稽核區間內系統查詢總件數及一般帳號與管理帳號數量，此處數據均係指該區間內**累積總數**（帳號使用者不重複列入），可輔佐圖表呈現各單位、各月份使用查詢數據，並簡要說明數字差異之理由及抽樣比率。

表 23. 本府核心系統 109 年 1-3 月使用現況分析統計

系統名稱	使用單位	個人帳號使用者	管理帳號使用者	查詢件數
戶役政系統	本府民政局	20	7	113
	本市 12 區戶政事務所	687	84	1,244,198
	本市 12 區區公所	115	20	511,618
水費水表營收系統	自來水事業處	295	4	557,331
第三代公路監理資訊系統	交通事件裁決所	148	1	125,332
	停車管理工程處	52	1	1291
	公共運輸處	50	1	2558
不動產數位資料庫系統	地政局	56	6	13,395
	本府外機關	未計算	112	536,325
社會福利資訊系統	本府各機關暨民間照護機構	2,020	6	49.959 (筆 / 天)
勤區查察處理系統	警察局	2,517	125	818,027
全國財產總歸戶系統	稅捐稽徵處	109	1	25,125

權限管理情形

說明管理者之業務職掌內容，是否有複檢機制等，通常系統使用人員可依管理權限區分為以下：

表 24. 系統使用人員分類表

人員	說明	權責
一般使用者	使用機關內申請使用系統授權管制項目之人員	遵守系統使用規定
單位管理者	所屬單位地點分散於各行政區，或單位內一般使用者總數達一定人數，得設置單位管理者角色	辦理單位內一般使用者帳號新增、異動、復權及註銷作業。 每月列印或匯出系統使用者紀錄陳核單位主管。 定期檢討單位內一般使用者之帳號與權限，並作成紀錄。
使用機關管理者（外機關）	為使用機關與管理機關之聯絡窗口	辦理機關內一般使用者與單位管理者帳號新增、異動、復權及註銷作業。 每月列印或匯出系統使用紀錄，分送各使用單位主管。 定期檢討一般使用者及單位管理者之帳號與權限，並作成紀錄。
系統管理者	最高權限之管理者	辦理各使用機關之機關管理者帳號新增、異動、復權及註銷作業。 辦理各使用機關單位管理者之審核及設定作業。 定期檢討各使用機關之機關管理者權限，並作成紀錄。 辦理其他系統管理相關作業。
帳號權限管理者	機關使用單一窗口平台登入介接各資訊系統者，使用者帳號為統一管理，各系統內部權限才由系統管理者個別設定	不涉及系統管理部分，僅就單一窗口平台帳號進行管理作業。

可說明機關現行權限管理作業方式，含新增、修改、刪除權限之作業規定及辦理情形，就下列項目進行查核：

表 25. 系統權限管理項目表

查核項目	查核內容	查核結果
建置系統授權單位使用人員資料	各單位應確實建置系統使用者名單，內容包括股別、帳號、名稱、啟（停）用日期	單位現有使用系統人員數、單位配置及約僱委外帳號名冊
系統使用者異動時，及時更正系統權限	參照機關派令、帳號異動申請單及內部人員異動簽會紀錄，與帳號權限刪除紀錄做比對	新增使用人員名單、停用人員名單及帳號刪除紀錄。
檢視有無 3 個月以上未使用系統之人員	確認單位使用人員，有無因公出國考察、借調支援、留職停薪及延長病假等達 3 個月未使用系統之情形，如有前述情事應停用或刪除其帳號。	3 個月以上未使用系統之使用者名單、佐證資料及相關簽呈
檢視系統使用者清單與業務職掌相符	檢視系統使用者帳號權限與實際承辦業務是否相符	使用者清單、業務職掌表及分工說明

異常情形分析

針對前述訂定之異常存取項目進行系統查詢資料篩選後，逐一說明發生原因，並進一步要求提供相關查調依據，查證有無非因公查詢情事。

1. 借用或共用帳號情形

概要	比對〇〇系統 109 年〇月份使用者紀錄檔與同仁差勤，發現有 2 筆同仁當日未上班卻有登入系統查詢之紀錄。
說明	經瞭解，其中一件係因同仁當日帳號出現異常無法登入，又為代理同仁處理業務，故借用未出勤同仁之帳號作使用；另一件係同仁本無系統權限帳號，因業務所需，臨時使用休假同仁帳號，該同仁已向資訊室提出帳號申請。
改善措施	使用者帳號應具唯一識別性與鑑別性，經查同仁借用帳號均係公務需求，惟因該系統涉及民眾個資，各單位仍應避免類此情形發生，政風室將持續宣導同仁勿將帳號密碼交由他人使用或共用，並請各單位主管督促並定期自檢。

2. 使用者登入次數異常頻繁

概要	某同仁 3 個月內登入系統次數達 2 千餘次，較次高登入次數 3 百餘次、平均登入次數 70 次有明顯差距
說明	經詢問查調人員，其表示使用習慣為每查詢 1 筆即登出入 1 次，且其業務職掌包含產出相關報表，使用頻率本來就較一般使用人員高，且經分析比對查詢內容，並無集中於特定查詢鍵植，尚無不當查詢情事。
改善措施	體醒同仁系統次數登出入頻率過高容易被稽查，建議其改變使用習慣，以提高異常存取勾稽之正確性。

3. 使用者查詢內容與登載之案號或查詢事由不符

概要	比對系統查詢紀錄與查詢依據，發現有未提供佐證資料疑非依公務查詢案件
說明	經詢問查詢人員，渠表示係為檢測系統是否正常運行，而輸入同仁自身資料作測試，並提供資料佐證確實為該同仁資料，未有不當查詢民眾個資等情。
改善措施	同仁使用自身資料作系統測試，亦屬公務上用途，未違反相關規定，建議可適當註記並備妥資料供查核；如有業務需求必須以民眾資料作系統測試，需事前簽奉主管核可，並妥善使用保管，勿從事公務以外用途。

4. 使用者登入失敗次數異常頻繁

概要	某同仁 3 個月內登入系統失敗次數達 2 百餘次，平均每日登入失敗 4 次
說明	經查調該帳號輸入錯誤之鍵植，為正確帳號之大寫字元，同仁說明其因業務關係經常登入他系統，因他系統限定使用大小寫英數混合字元，故切換系統使用時疏未注意輸入大寫帳號，導致登入失敗次數異常頻繁。
改善措施	體醒同仁於輸入帳號密碼時多加留意，以提高異常存取勾稽之正確性；系統管理者應考慮建置帳密輸入次數過多之鎖定機制，以堵絕不法人士刻意猜測密碼，保護系統安全。

缺失態樣

1. 權限管理缺失

概要	經比對系統權限帳號清冊與在職人員名冊，查有使用者○○○（101 年 9 月○日離職）、○○○（108 年 10 月○日離職）、及○○○（109 年 3 月○日離職）尚未註銷○○○系統使用權限。
說明	經查○○處離（休）職人員系統權限設定由 A 科權管，並於會辦離職報告單時記載取消使用權限時間，惟稽核時發現○○系統帳號管理為 B 科專責業務，離職報告單於該科項下無系統註銷欄位，未建立明確帳號刪除流程，致生疏漏刪除情事。
改善措施	精進權限控管作為，離（休）人員權限之註銷、職務異動人員權限之調整等事項，應由系統管理者定期辦理權限清查作業，並簽奉主管核示，以落實權限帳號管控。

2. 非因公務查詢民眾個資

概要	○○分局○○派出所○員為滿足一時好奇，及欲向同事展示其本人、太太及高中時期女友之相片，請同事領用並登入 M-Police 後再由○員進行查詢，○員因不知前女友 A 及 B 之身分證號，遂以「警政知識聯網」之「勤區查察處理系統」、「戶役政查詢系統」查詢後，逐一輸入 M-Police 查詢，並向同事展示查得之相片。
說明	○員非因公查詢已違反「警察機關資通安全實施規定」第二十四點第三項：「(二)非因公務擅自查詢公務機密資料經查屬實，尚未達洩密，視情節輕重核予申誡二次以下懲處。」，經分局依「警察機關人員獎懲標準」第六條第一項第一款：「不遵規定執行職務或執行公務不力，情節輕微」，核予申誡二次處分。

改善措施	除定期及不定期抽查警政知識聯網各系統使用情形，稽核員警查詢資料是否均係公務查詢外，持續加強辦理資安教育宣導，利用各項集會場合，宣導資訊安全管理規定、違規案例及可能導致洩密管道與因素，督促員警養成正確觀念，提升員警資安觀念及保密意識，落實公務機密維護工作。
------	---

3. 其他違失情事

說明	如機關辦理資訊服務採購契約未依工程會範本、同仁假日查詢系統未刷進退卡及申請加班、系統未建置公文案號或查詢事由欄位等。
----	--

建議事項

一、法規面

關於資訊查詢系統之相關法規命令、內部文件或作業手冊有無未盡完善之處？機關同仁對於資訊安全意識之觀念為何？

有關政風單位於資訊使用管理之角色定位有無明確？哪些系統依規定須由政風室辦理稽核？

使用共用系統之機關，並應檢視內部作業手冊規範，有無落實遵循中央法規要求。

二、制度面

依循資通安全管理法之規定，於機關內推行之各項作為如 ISMS 之導入、帳號管理、通訊與傳遞之保護等，有無落實？

機關對於系統使用者之稽核紀錄軌跡有無確實保存與備份，能否勾稽其中有異常情形項目者？又相關異常存取或資安事件之建立與通報機制有無完善？

使用單位自主查核之程序有無落實？有無逐案陳核並有簽呈紀錄？有無查核人員與查調人員為同一人之情形？遇有異常情形時是否有循相關管道聯繫通報？

三、執行面

前述各項制度之實際推行層面，有無遭遇短期內難以克服之阻礙？或在機關首長的重視程度、資訊室與受稽核單位之配合度、政風室人力的調配上，有無遭遇問題之處。

表次

- 表 1. 資訊稽核比較表
- 表 2. 系統風險評估指標表
- 表 3. 資訊使用管理稽核實施計畫表
- 表 4. 系統查詢軌跡紀錄檔工作項目表
- 表 5. 異常存取情形項目表
- 表 6. 稽核紀錄措施項目表
- 表 7. 系統登入次數異常指標表
- 表 8. 系統查詢時段異常指標表
- 表 9. 系統使用時間異常指標表
- 表 10. 查詢筆數異常指標表
- 表 11. 行政院 108 年公務機關資安稽核項目表
- 表 12. 本府 109 年度資訊使用管理稽核項目表
- 表 13. 第三方驗證機構清冊
- 表 14. 資訊系統清冊
- 表 15. 資訊系統安全等級評估表
- 表 16. 各級機關資通教育訓練要求時數表
- 表 17. 個資法安全維護措施事項表
- 表 18. 個資盤點表
- 表 19. 財產申報審查業務個資盤點表
- 表 20. 資訊資產清冊
- 表 21. 限制危害國家資通安全產品廠商清單
- 表 22. 109 年度本府資訊使用管理稽核擇選機關表
- 表 23. 本府核心系統 109 年 1-3 月使用現況分析統計
- 表 24. 系統使用人員分類表
- 表 25. 系統權限管理項目表

圖次

- 圖 1. 本府各級機關（構）資安等級分布同心圓
- 圖 2. 警政日誌巨量資料分析系統介面圖
- 圖 3. 教育局教網中心系統查詢紀錄軌跡介面圖
- 圖 4. 地政局資訊系統登入紀錄查詢頁面
- 圖 5. 民政局資訊系統資料庫備份畫面
- 圖 6. 自來水事業處磁帶存放紀錄表
- 圖 7. 行政院資通安全處訂定新進人員資安宣導單（範本）
- 圖 8. 資訊服務採購契約範本 - 廠商保密同意書
- 圖 9. 資訊服務採購契約範本 - 廠商人員保密切結書



臺北市府政風處

109年9月份編印

地址：110204臺北市信義區
市府路1號11樓西南區

傳真電話：(02)2759-5690

肅貪熱線：1999轉1743

